

Faculty of Informatics Engineering
Department of Systems Security
and Computer Networking



Cloud Identity Access Management Security Honeypot and Analyzer

Supervised by:

**Dr. Christine Zenieh
Eng. Mouhamad Amjad Al Safadi**

Prepared by :

Gabriella Haddad
Elyana Koryakos
Khalid Alnabulsi

2025/2026

SUPERVISOR CERTIFICATION

I certify that the preparation of this project entitled **Cloud Identity Access Management Security Honeypot and Analyzer**, prepared by Gabriella Haddad, and Elyana Koryakos, and Khalid Alnabulsi, was made under my supervision at Faculty of Computer, Informatics & Communication Engineering in partial fulfillment of the Requirements for the Degree of Bachelors of Systems Security & Computers Networks Engineering.

Name:

Signature:

Date:

الملخص

أصبحت أمن المعلومات السحابية في السنوات الأخيرة من القضايا المحورية التي تحظى باهتمام متزايد لدى المؤسسات، في ظل الانتقال المتسارع من البنى التحتية التقليدية إلى البيئات السحابية. ورغم ما توفّره هذه البيئات من مزايا تتعلّق بالمرونة، وقابلية التوسّع، والكفاءة التشغيلية، فإن تعقيدها المتزايد أظهر تحديات أمنية جديدة، ومن أبرز هذه التحديات إدارة الهوية والصلاحيات.

تمثّل إدارة الهوية والصلاحيات (Identity and Access Management – IAM) الأساس الذي تُبنى عليه آليات التحكم بالوصول إلى الموارد السحابية. ومع توسّع البيئات السحابية وتعدّد مكّوناتها، تتزايد درجة التعقيد في علاقات الصلاحيات بين المستخدمين، والأدوار، والسياسات الأمنية، نتيجة التغيّرات المستمرة في الهياكل التنظيمية والوظيفية. ويؤدي هذا التعقيد في كثير من الحالات إلى ظهور أخطاء في تهيئة سياسات IAM أو إلى تراكم غير مقصود للصلاحيات، وهي مشكلات قد لا يتم اكتشافها بالاعتماد على المراجعة التقليدية لإعدادات الوصول فقط.

تهدف هذه الدراسة إلى مناقشة إطار نظري منظم لتحليل أنظمة إدارة الهوية والصلاحيات في البيئات السحابية، من خلال التركيز على تنظيم مكّونات IAM، ودراسة العلاقات بين المستخدمين والأدوار والصلاحيات، إضافة إلى تحليل السياسات الأمنية من منظور تحليلي ساكن. كما تتناول الدراسة كيفية تنظيم الصلاحيات في أنظمة إدارة الهوية والصلاحيات، مع التركيز على سياسات الوصول وتوزيع الامتيازات.

كما يناقش البحث مفهوم المصائد الأمنية (Honeypots) كما ورد في الأدبيات البحثية، بوصفها إحدى الآليات المستخدمة في الدراسات الأمنية لتحليل أنماط سلوك التهديدات المحتملة. ويُطرح هذا المفهوم في سياق تكاملي مع تحليل أنظمة إدارة الهوية والصلاحيات، بهدف الربط بين سلوك التهديدات من جهة، ونقاط الضعف المرتبطة بتهيئة سياسات الوصول وتوزيع الصلاحيات من جهة أخرى، بما يوفّر إطاراً نظرياً يدمج بين دراسة سلوك التهديدات وتحليل الثغرات المرتبطة بإدارة الصلاحيات في البيئات السحابية.

الفهرس

10	1 الفصل الأول - الدراسة النظرية
10	1.1 الحوسبة السحابية (Cloud Computing) :
10	1.1.1 تعريف الحوسبة السحابية [1]
10	1.1.2 نماذج النشر في السحابة (Cloud Deployment Models) [2]
10	1.1.3 نماذج الخدمة في السحابة (Cloud Service Models) [1]
11	1.1.4 خصائص الحوسبة السحابية (Cloud Characteristics) [1]
11	1.1.5 أمن السحابة (Cloud Security) [3]
12	1.1.6 التحديات الأمنية في الحوسبة السحابية (Cloud Security Challenges) [4]
13	1.1.7 العلاقة بين الحوسبة السحابية وإدارة الهوية والصلاحيات
13	1. إدارة الهوية والصلاحيات IAM
13	1.2.1 تعريف IAM ودوره في أمن السحابة [5]
13	1.2.2 مكونات IAM الأساسية [8]
14	1.2.3 آليات التحقق من الهوية (Authentication) [8]
15	1.2.4 آليات التفويض ونماذج التحكم بالوصول (Authorization) [8]
17	1.2.5 أخطاء إعداد IAM (IAM Misconfigurations) [7]
17	1.2.6 تأثير سوء إعداد IAM على الأمن السحابي [7]
18	1.2.7 أهمية تحليل أنظمة IAM في البيئات السحابية [8]
18	1.2.8 دور IAM في تعزيز أمن السحابة [5]
19	1.2.9 الاتجاهات المستقبلية في إدارة الهوية والصلاحيات (Future Trends in IAM) [8]
20	1.3 أدوات تحليل IAM السحابية (IAM Analysis Tools) [8]
20	1.4 سياسات إدارة الهوية والصلاحيات (IAM Policies) [8]
21	1.5 المصائد الأمنية (Honeypots)
21	1.5.1 تعريف المصائد الأمنية [9]

21	1.5.2 أنواع المصائد الأمنية [10]
22	1.5.3 دور المصائد الأمنية في البيئات السحابية [11]
22	1.5.4 التحديات والمخاطر المرتبطة باستخدام Honeypots [10]
22	1.5.5 المصائد الأمنية القائمة على السحابة (Cloud-Based Honeypots) [11]
23	1.6 تصنيف المستخدمين (User Classification)
23	1.6.1 تعريف المستخدم الشرعي (Legitimate User) [8]
23	1.6.2 تعريف المهاجم (Attacker) [5]
24	1.7 السجلات (Logs)
24	1.7.1 تعريف السجلات [11]
24	1.7.2 نظام تسجيل السجلات (Log Recording Systems) [11]
24	1.7.3 مكونات نظام تسجيل السجلات [11]
24	1.7.4 آلية تبادل السجلات (Log Transmission Mechanism) [11]
27	2 الفصل الثاني - الدراسات السابقة
27	2.1 الدراسات السابقة....
30	2.2 مقارنة بين المشروع والدراسات السابقة
32	2.3 الإطار التحليلي المعتمد في المشروع....
35	3 الفصل الثالث - منهجية العمل والتصميم....
35	3.1 منصة Openstack
35	3.1.1 المكونات الأساسية في OpenStack
36	3.1.2 فوائد استخدام OpenStack
36	3.1.3 OpenStack كبيئة اختبار سحابية
36	3.2 منصة MicroStack
36	3.2.1 المكونات المستخدمة ضمن MicroStack
37	3.2.2 الفرق بين OpenStack وMicrostack

37	3.3 أداة تحليل إدارة الهوية والصلاحيات (IAM Analyzer)
37	3.3.1 مرحلة التجميع (Collection Phase)
38	3.3.2 مرحلة التهيئة والمعالجة المبدئية (Normalization Phase)
39	3.3.3 مرحلة بناء الرسم البياني (Graph Construction Phase)
39	3.3.4 مرحلة القواعد الساكنة (Static Rules Phase)
40	3.3.5 آلية الأتمتة والتنبيه
40	3.4 المصيدة الأمنية (Honeypot)
40	3.4.1 تصميم بيئة المصيدة الأمنية ضمن MicroStack
40	3.4.2 دور المصيدة الأمنية في رصد السلوك داخل البيئة السحابية
40	3.4.3 تكامل المصيدة الأمنية مع أداة تحليل إدارة الهوية والصلاحيات
41	3.5 تكامل مكونات النظام والبنية العامة
44	4 الفصل الرابع – التطبيق العملي والنتائج
44	4.1 تطوير أداة تحليل إدارة الهوية والصلاحيات (IAM Analyzer)
44	4.1.1 بنية الأداة وآلية التكامل مع بيئة MicroStack
45	4.1.2 جمع البيانات من بيئة MicroStack (Collection Phase)
47	4.1.3 معالجة وتوحيد البيانات (Normalization and Preprocessing)
49	4.1.4 بناء الرسم البياني وتحليل الوصول (Graph Construction & Reachability)
52	4.1.5 مرحلة القواعد الساكنة (Static Rules Phase)
55	4.2 إنشاء المصيدة الأمنية (Honeypot Deployment)
56	4.2.1 نشر خادم افتراضي مخصص للمصيدة
56	4.2.2 إنشاء شبكة منطقية معزولة للمصيدة وربطها بالموّجه
56	4.2.3 ضبط سياسة الوصول باستخدام مجموعات الأمن (Security Groups)
57	4.2.4 تهيئة مبدأ جمع الأدلة (Evidence) من السجلات
57	4.3 نتائج التحليل التجريبي (Experimental Results)

58	4.3.1 تنفيذ السيناريو وجمع البيانات.....
58	4.3.2 النتائج المكتشفة بواسطة القواعد الساكنة.....
59	4.3.3 تفسير النتائج وحدودها (Result Interpretation & Limitations).....
59	4.3.4 النتائج الإيجابية الكاذبة (False Positives).....
62	الخاتمة:.....
63	المراجع:.....

المقدمة

شهد العقد الأخير تحوُّلاً جذرياً في مفهوم البنية التحتية لتكنولوجيا المعلومات، حيث أصبحت الحوسبة السحابية أحد الركائز الأساسية للتحوُّل الرقمي على المستوى العالمي، لما توفّره من مرونة تشغيلية، وقابلية عالية للتوسُّع، وكفاءة في إدارة الموارد. وقد أدّى هذا التحوُّل إلى اعتماد منصّات سحابية مفتوحة وموزّعة، مثل OpenStack، الذي يتيح بناء بيئات سحابية مرنة وقابلة للتخصيص وفق احتياجات المؤسسات المختلفة. وبالاعتماد على هذا الإطار، تم استخدام MicroStack بوصفه نسخة مبسّطة من OpenStack، تُستخدم كبيئة محاكاة وتجريب، تُمكن من تمثيل البنية السحابية ودراسة آلياتها التشغيلية والأمنية.

إلا أن الانتقال إلى البيئات السحابية أدّى إلى تغيّر في أساليب الحماية التقليدية، حيث لم تعد النماذج المعتمدة على حدود الشبكة الثابتة كافية لحماية الأنظمة. ويعود ذلك إلى طبيعة البيئات السحابية التي تعتمد على موارد موزّعة وتسمح بالوصول من مواقع متعددة، مما يفرض تحديات جديدة في إدارة الوصول وحماية الموارد الرقمية.

في هذا السياق، برزت إدارة الهوية والصلاحيات (Identity and Access Management – IAM) بوصفها المكوّن المحوري للتحكّم بالوصول في البيئات السحابية، إذ تعتمد هذه البيئات بشكل أساسي على الهوية لتحديد الصلاحيات الممنوحة للمستخدمين والكيانات المختلفة. غير أن تعقيد سياسات الوصول وتنوّع الأدوار في الأنظمة السحابية الحديثة، إلى جانب التغيّرات المستمرة في الهياكل التنظيمية، يؤدّي في كثير من الحالات إلى أخطاء في تهيئة أنظمة IAM أو إلى تراكم غير مقصود للصلاحيات، ما يزيد من احتمالية ظهور مخاطر أمنية يصعب اكتشافها بالاعتماد على المراجعة اليدوية أو الأساليب التقليدية.

وانطلاقاً من ذلك، تهدف هذه الدراسة إلى تناول تحليل أنظمة إدارة الهوية والصلاحيات في البيئات السحابية ضمن إطار منهجي يجمع بين دراسة بنية الصلاحيات وتحليل سلوك التهديدات المحتملة. ويركّز الجانب العملي من الدراسة على تصميم وتنفيذ إطار تحليلي لتقييم تهيئة أنظمة IAM في بيئة سحابية مبنية على OpenStack، وذلك من خلال جمع بيانات الهوية والصلاحيات، وتحليل العلاقات بين المستخدمين والأدوار وسياسات الوصول، وتمثيل هذه العلاقات بشكل منظمّ يتيح دراسة تداخل الصلاحيات وتراكمها.

ويقتصر نطاق هذا العمل على دراسة وتحليل الجوانب المرتبطة بإدارة الهوية والصلاحيات في البيئات السحابية، مع التركيز على الكشف عن مشكلات التهيئة وتداخل الصلاحيات من منظور تحليلي منهجي. وتسعى الدراسة إلى تقديم فهم أوضح لبنية أنظمة IAM ومصادر المخاطر المرتبطة بها، بما يوفّر أساساً علمياً يمكن الاستفادة منه في أعمال بحثية لاحقة ضمن مجال أمن الحوسبة السحابية.

الفصل الأول

الدراسة النظرية

1 الفصل الأول - الدراسة النظرية

يستعرض هذا الفصل المفاهيم النظرية الأساسية التي يستند إليها هذا البحث، بدءاً من الحوسبة السحابية ونماذجها المختلفة، مروراً بأمن السحابة وأنظمة إدارة الهوية والصلاحيات (IAM)، وصولاً إلى تقنيات المصادد الأمنية وأدوات تحليل أنظمة IAM. يهدف هذا الفصل إلى بناء إطار معرفي نظري يوضح الأسس المفاهيمية المرتبطة بإدارة الوصول وأمن الهوية في البيئات السحابية.

1.1 الحوسبة السحابية (Cloud Computing) :

الحوسبة هي عملية معالجة البيانات باستخدام أجهزة الكمبيوتر لتنفيذ مهام محددة، سواء كانت حسابية أو منطقية أو غيرها. تشمل الحوسبة تصميم وبناء أنظمة الكمبيوتر، وتطوير البرمجيات، وتحليل البيانات، والذكاء الاصطناعي، والعديد من التطبيقات الأخرى.

1.1.1 تعريف الحوسبة السحابية [1]

نمط من أنماط الحوسبة حيث تتيح للمستخدم الوصول التلقائي حسب الطلب إلى موارد حاسوبية افتراضية (مثل الشبكات، الخوادم، التخزين، التطبيقات، والخدمات) من دون الحاجة إلى شراء أو إدارة هذه الموارد مادياً. تعتمد هذه التقنية على مراكز بيانات ضخمة يتم التحكم بها مركزياً، وتُدار بكفاءة عالية لضمان استمرارية الخدمة. تُعد الحوسبة السحابية ثورة في مجال تكنولوجيا المعلومات، كونها توفر المرونة، التوسع حسب الطلب، وخفض التكاليف التشغيلية للمؤسسات.

1.1.2 نماذج النشر في السحابة (Cloud Deployment Models) [2]

تعتمد بيئات الحوسبة السحابية على ثلاثة نماذج نشر رئيسية تُختار وفقاً لمتطلبات الأمان، الخصوصية، الحوكمة، والأداء:

- السحابة العامة (Public Cloud): يملكها ويشغلها مزود خدمات خارجي، وتُتاح عبر الإنترنت لعامة المستخدمين ويتميز بالتكلفة المنخفضة والمرونة العالية بسعر الاستخدام حسب الطلب.
 - السحابة الخاصة (Private Cloud): تُنشأ وتُدار داخلياً داخل مؤسسة واحدة، سواء في مركز بيانات خاص أو من قبل مزود مؤمن.
 - السحابة الهجينة (Hybrid Cloud): تدمج بين السحابة العامة والخاصة، ما يتيح نقل البيانات والتطبيقات بين النماذج حسب الحاجة.
- الاختيار بين هذه النماذج يعتمد على مستوى الخصوصية والحساسية المطلوبة، التكلفة، الحوكمة، وقدرة المنظمة على إدارة البنية التحتية التقنية.

1.1.3 نماذج الخدمة في السحابة (Cloud Service Models) [1]

تنقسم الحوسبة السحابية إلى ثلاث طبقات لتقديم الخدمة، تختلف كل منها في مستوى التحكم الإداري وموارد البنية التحتية التي يتحكم بها المستخدم:

- SaaS – البرمجيات كخدمة (Software as a Service): توفر الوصول إلى تطبيقات جاهزة تعمل عبر الإنترنت دون الحاجة لأي إدارة للبنية التحتية أو نظام التشغيل بحيث يقتصر دور المستخدم على إعدادات التطبيق فقط، بينما يتحمل المزود مسؤولية تشغيل الخادم، التخزين، الشبكة والتحديثات.
 - PaaS – المنصة كخدمة (Platform as a Service): تقدم بيئة متكاملة لتطوير التطبيقات ونشرها، تشمل نظام تشغيل، قواعد بيانات، خوادم تطبيقات وأطر عمل، مما يتيح للمطورين التركيز على البرمجيات بينما يدير المزود البنية التحتية.
 - IaaS – البنية التحتية كخدمة (Infrastructure as a Service): توفر موارد حاسوبية أساسية مثل الخوادم الافتراضية، التخزين، والشبكات للتحكم الكامل من قبل المستخدم، الذي يدير نظام التشغيل والتطبيقات. البنية التحتية الفعلية والافتراضية تُدار من قبل المزود، ويحاسب المستخدم حسب الاستخدام.
- تُوفر هذه النماذج مستويات مختلفة من الإدارة والمرونة وتُستخدم بحسب احتياجات المؤسسة.

1.1.4 خصائص الحوسبة السحابية (Cloud Characteristics) [1]

تُعرف الحوسبة السحابية بخمسة خصائص تقنية أساسية تجعلها خياراً استراتيجياً لتشغيل الأنظمة الرقمية.

من أهم هذه الخصائص:

- الوصول الفوري عند الطلب (On-Demand Self-Service): يمكن للمستخدم طلب موارد دون تدخل بشري.
- الوصول الواسع عبر الشبكة (Broad Network Access): يمكن الوصول إلى الخدمات من أي مكان.
- تجميع الموارد (Resource Pooling): يتم تجميع الموارد لخدمة عدة عملاء وفقاً لمبدأ تعدد المستأجرين.
- المرونة القابلة للتوسع (Rapid Elasticity): يمكن توسيع الموارد أو تقليصها ديناميكياً.
- الخدمة المقاسة (Measured Service): يتم قياس استخدام الموارد وتُحسب الرسوم حسب الاستخدام الفعلي.

تتيح هذه الخصائص توفير بيئة تشغيلية مرنة وآمنة ومتوافقة مع احتياجات المؤسسات الحديثة.

1.1.5 أمن السحابة (Cloud Security) [3]

أمن الحوسبة السحابية هو مجموعة من الضوابط التقنية والتنظيمية المصممة لحماية بيانات التشغيل السحابية من التهديدات المتقدمة ومخاطر فقدان البيانات.

يختلف أمن السحابة عن أمن البنى التقليدية نتيجة خصائصها مثل تعدد المستأجرين (Multi-tenancy) والاعتماد على الاتصال الواسع بالشبكة. ولهذا، يتطلب الأمر حلاً أمنياً مصمماً خصيصاً لخصائص السحابة.

تشمل الممارسات الأساسية لأمن السحابة ما يلي:

- التحكم في الهوية والوصول (IAM): اعتماد نموذج صارم لإدارة الهوية.
- تشفير البيانات (Data Encryption): حماية البيانات أثناء النقل وأثناء التخزين مع ضمان إدارة فعالة للمفاتيح.
- العزل الأمني (Tenant Isolation): وضع آليات عزل صارمة بين المستأجرين لضمان عدم تسرب البيانات بين العملاء المشتركين في البنية نفسها.
- الرصد المستمر (Continuous Monitoring): الاعتماد على أدوات تحليل سلوكي، وكشف التهديدات، وتسجيل الأنشطة (Log Auditing) لتحديد الأنماط غير الطبيعية والاستجابة للحوادث بسرعة.
- الدفاع متعدد الطبقات (Defense in Depth): توزيع الضوابط الأمنية عبر طبقات مختلفة (الشبكة، الأجهزة الافتراضية) لتوفير حماية متكاملة ومرنة.

1.1.6 التحديات الأمنية في الحوسبة السحابية (Cloud Security Challenges) [4]

رغم الميزات العديدة التي تقدمها الحوسبة السحابية، إلا أن هناك تحديات أمنية بارزة يجب الانتباه لها ومن أهم هذه التحديات:

- تنفيذ التكوينات غير الآمنة (Misconfiguration): يحدث هذا التحدي عندما يتم إعداد مكونات النظام السحابي (مثل التخزين، أو قواعد البيانات، أو إعدادات الشبكة) بشكل غير صحيح، مما يفتح ثغرات قد يستغلها المهاجمون للوصول غير المصرح به إلى البيانات أو الخدمات.
 - تعدد المستأجرين: في بيئات الحوسبة السحابية، قد تتشارك عدة كيانات أو مستخدمين نفس الموارد، مما يزيد من احتمالية حدوث أخطاء في تحديد الأذونات والصلاحيات، وبالتالي يزيد من خطر وصول المستخدمين إلى بيانات أو خدمات لا يُفترض بهم الوصول إليها.
 - هجمات الشبكة مثل DDoS واعتراض البيانات: تعتبر هجمات حجب الخدمة (DDoS) من التهديدات الخطيرة في البيئة السحابية، إذ يستطيع المهاجم إرسال كميات هائلة من البيانات لتعطيل الخدمات السحابية. كما أن اعتراض البيانات أثناء نقلها بين المستخدمين والخدمات السحابية قد يؤدي إلى تسرب معلومات حساسة إذا لم يتم استخدام بروتوكولات التشفير المناسبة.
 - إدارة المفاتيح المعقدة: تعتمد الخدمات السحابية على تشفير البيانات لضمان سريتها وإن إدارة مفاتيح التشفير بشكل غير صحيح يؤدي إلى فقدان الوصول إلى البيانات أو تسريب المفاتيح للمهاجمين، مما يعرض البيانات لخطر الانكشاف.
- هذه التحديات تتطلب اعتماد ضوابط صارمة، مثل التشفير الطرفي، مراجعة الصلاحيات، واستخدام تقنيات مراقبة متقدمة لضمان حماية البيئة السحابية بشكل فعال.

1.1.7 العلاقة بين الحوسبة السحابية وإدارة الهوية والصلاحيات

مع الاعتماد المتزايد على نماذج الحوسبة السحابية، ولا سيما البيانات القائمة على IaaS و PaaS، لم تعد آليات الحماية التقليدية القائمة على العزل الشبكي كافية لضمان أمن الموارد والخدمات. في هذا السياق، أصبحت الهوية الرقمية هي المحور الأساسي للتحكم بالوصول، حيث تعتمد معظم العمليات السحابية على التحقق من هوية المستخدم أو الخدمة قبل السماح بأي تفاعل مع الموارد. يشكل هذا التحول الأساس النظري لظهور أنظمة إدارة الهوية والصلاحيات كعنصر مركزي في أمن السحابة، إذ يتم من خلالها ضبط الوصول، تقليل الصلاحيات غير الضرورية، ومراقبة الأنشطة بشكل دقيق. كما تشير الدراسات الحديثة إلى أن فعالية أمن السحابة ترتبط بشكل مباشر بمدى نضج سياسات IAM وتكاملها مع آليات المراقبة والتحليل الأمني.

1.2 إدارة الهوية والصلاحيات IAM

تُعتبر إدارة الهوية والصلاحيات (IAM) جوهرًا في البنية الأمنية لأي نظام رقمي، وخصوصاً في بيئات الحوسبة السحابية، حيث يتنوع المستخدمون وتزداد نقاط الدخول والخروج من النظام.

1.2.1 تعريف IAM ودوره في أمن السحابة [5]

IAM هو إطار عمل يتضمن السياسات والتقنيات المستخدمة لتحديد هوية المستخدمين، والتحكم في صلاحياتهم، وإدارتها عبر أنظمة تقنية متعددة. في الحوسبة السحابية يعمل IAM كخط الدفاع الأول، حيث يضمن أن كل عملية وصول إلى المورد تخضع للتحقق والتفويض المناسبين. يشمل دور IAM في أمن السحابة:

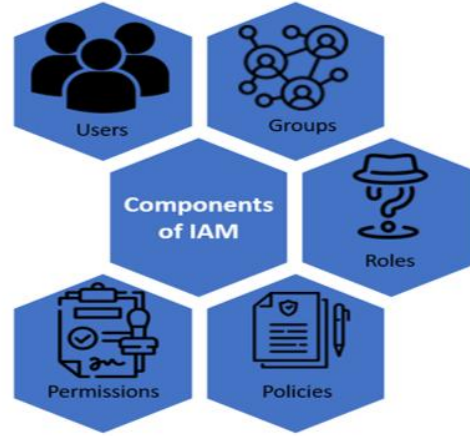
- التأكد من أن كل مستخدم أو خدمة يتم تعريفها والتحقق منها (Authentication).
- تحديد ما يُسمح لكل مستخدم بفعله (Authorization).
- تسجيل ومراجعة جميع الأنشطة لضمان الشفافية والتحقق في حال وقوع حوادث أمنية.

1.2.2 مكونات IAM الأساسية [8]

يتكوّن نظام IAM من مجموعة من العناصر الأساسية:

- Users (المستخدمون): يمثلون الأفراد أو الكيانات التي تطلب الوصول إلى موارد معينة.
 - Roles (الأدوار): مجموعة من الصلاحيات تُمنح لمجموعة من المستخدمين.
 - Policies (السياسات): قواعد مكتوبة تحدد ما يمكن وما لا يمكن للمستخدم أو الدور فعله.
 - Permissions (الأذونات): التصاريحات المحددة للوصول إلى مورد معين أو تنفيذ إجراء ما.
- يتم تنظيم هذه المكونات عبر واجهات متقدمة توفرها منصات مثل AWS IAM أو Azure Active Directory لضمان الدقة والقابلية للإدارة في بيئة معقدة.

ويُوضّح الشكل (1-1) مكوّنات أنظمة إدارة الهوية والصلاحيات، إذ تُشكّل هذه المكوّنات البنية الأساسية التي يعتمد عليها التحكم بالوصول في البيئات السحابية. حيث يتم تعريف المستخدمين وتنظيمهم ضمن مجموعات، ثم إسناد أدوار تحتوي على مجموعة من الصلاحيات المحددة عبر سياسات وصول. يتيح هذا الفصل البنيوي مرونة عالية في الإدارة، ويساعد في تقليل الاعتماد على التهيئة الفردية، إلا أنه قد يؤدي إلى تعقيد متزايد في حال غياب الضبط المنهجي للعلاقات بين هذه المكوّنات.



الشكل 1-1 المكوّنات الأساسية لأنظمة إدارة الهوية والصلاحيات (IAM) [8]

1.2.3 آليات التحقق من الهوية (Authentication) [8]

تُعدّ آليات التحقق من الهوية عنصراً أساسياً في أنظمة إدارة الهوية والصلاحيات، إذ تهدف إلى التأكد من أن المستخدم أو النظام الذي يطلب الوصول هو بالفعل الجهة المصرّح لها. وتعتمد البيئات السحابية الحديثة على مجموعة من تقنيات المصادقة لتعزيز مستوى الأمان وتقليل مخاطر الوصول غير المصرّح به. ومن أبرز آليات التحقق المعتمدة في البيئات السحابية الحديثة ما يلي:

- التحقق المعتمد على كلمة المرور (Password-based Authentication): يُعد من أقدم وأكثر أساليب التحقق انتشاراً، حيث يعتمد على مطابقة اسم المستخدم مع كلمة مرور سرّية. وعلى الرغم من سهولة تطبيقه وانخفاض تكلفته، إلا أنه يُعد محدود الفاعلية في مواجهة التهديدات الحديثة، نظراً لإمكانية تعرّض كلمات المرور لهجمات التخمين، والتصيد الإلكتروني، أو إعادة الاستخدام عبر أنظمة متعددة.
- المصادقة متعددة العوامل (Multi-Factor Authentication – MFA): تعتمد على استخدام أكثر من عامل تحقق مستقل، مثل الجمع بين شيء يعرفه المستخدم (كلمة المرور)، وشيء يملكه (هاتف ذكي أو رمز مؤقت)، أو سمة حيوية خاصة به. يساهم هذا الأسلوب في تعزيز مستوى

الأمان بشكل ملحوظ، إذ يقلل من احتمالية اختراق الحسابات حتى في حال تسريب بيانات الاعتماد الأساسية.

- تسجيل الدخول الموحد (Single Sign-On – SSO): يتيح للمستخدم المصادقة مرة واحدة للوصول إلى عدة أنظمة وخدمات مترابطة، مما يحسن تجربة المستخدم ويقلل من الحاجة إلى إدارة كلمات مرور متعددة. إلا أن هذا الأسلوب يتطلب ضوابط أمنية صارمة، نظراً لاعتماده على نقطة مصادقة مركزية قد تشكل هدفاً جذاباً للهجمات في حال عدم تأمينها بشكل كافٍ.

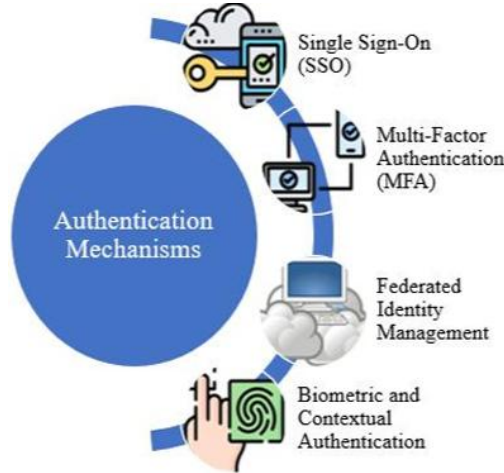
- إدارة الهوية الموحدة (Federated Identity Management):

تسمح للمستخدمين بالوصول إلى الخدمات السحابية باستخدام بيانات اعتماد من مزود هوية خارجي موثوق، مثل مزودات الهوية المؤسسية أو التجارية، مما يبسط إدارة الحسابات ويقلل من تكرار بيانات الاعتماد.

- المصادقة البيومترية والسياقية (Biometric and Contextual Authentication):

تعتمد المصادقة البيومترية على خصائص حيوية فريدة مثل بصمة الإصبع أو التعرف على الوجه، في حين تقوم المصادقة السياقية بتقييم عوامل إضافية مثل الموقع الجغرافي، نوع الجهاز، ونمط السلوك، لتقدير مدى موثوقية طلب الوصول.

ويوضح الشكل (2-1) آليات التحقق من الهوية الشائعة في أنظمة إدارة الهوية والصلاحيات، مبيّناً تكامل هذه الأساليب في تعزيز مستوى الأمان والتحكم بالوصول داخل البيئات السحابية الحديثة.



الشكل 2-1 آليات التحقق من الهوية في أنظمة إدارة الهوية والصلاحيات [8]

1.2.4 آليات التفويض ونماذج التحكم بالوصول (Authorization) [8]

تُعد آليات التفويض (Authorization) المرحلة التي تلي عملية التحقق من الهوية في أنظمة إدارة الهوية والصلاحيات، حيث يتم من خلالها تحديد الصلاحيات الممنوحة للكيان المصادق عليه، وما إذا كان مسموحاً

له تنفيذ عمليات محددة أو الوصول إلى موارد معينة داخل النظام. وتُعد هذه الآليات عنصراً أساسياً في حماية الموارد السحابية من الوصول غير المصرّح به أو الاستخدام المفرط للصلاحيات.

تعتمد أنظمة IAM في تنفيذ التفويض والتحكم بالوصول على مجموعة من المكونات التنظيمية، تشمل السياسات، الأدوار، وآليات المراجعة الدورية للصلاحيات. حيث تُستخدم السياسات (Policies) لتحديد القواعد التي تحكم الوصول إلى الموارد، ويتم إسنادها إلى المستخدمين أو المجموعات أو الأدوار. أما إدارة الأدوار (Role Management)، فتُمثّل الأساس في نماذج التحكم بالوصول المعتمدة على الدور، إذ يتم ربط الصلاحيات بالوظائف والمسؤوليات الفعلية للمستخدمين داخل المؤسسة. وتُستكمل هذه الآليات من خلال مراجعات الوصول الدورية وعمليات الاعتماد (Access Reviews and Certifications)، التي تهدف إلى التأكد من أن الصلاحيات الممنوحة لا تزال متوافقة مع متطلبات العمل والسياسات الأمنية المعتمدة.

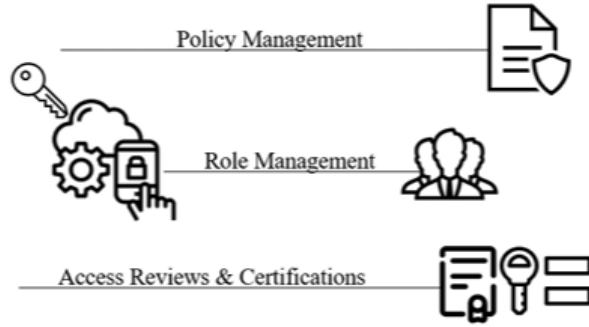
ومن أبرز نماذج التحكم بالوصول المستخدمة في أنظمة إدارة الهوية والصلاحيات ما يلي:

- التحكم بالوصول المعتمد على الدور (Role-Based Access Control – RBAC): يعتمد هذا النموذج على إسناد الصلاحيات إلى أدوار محددة، ثم ربط المستخدمين بهذه الأدوار وفق وظائفهم ومسؤولياتهم داخل المؤسسة. يساهم RBAC في تبسيط إدارة الصلاحيات وتحقيق مبدأ أقل الامتيازات، إلا أن استخدامه في البيئات الكبيرة والديناميكية قد يؤدي إلى ما يُعرف بمشكلة انفجار الأدوار، حيث يزداد عدد الأدوار بشكل يصعب إدارته أو مراجعته يدوياً.

- التحكم بالوصول المعتمد على السمات (Attribute-Based Access Control – ABAC): يركز هذا النموذج على اتخاذ قرارات الوصول بناءً على مجموعة من السمات المرتبطة بالمستخدم، المورد، أو السياق التشغيلي، مثل الموقع الجغرافي أو وقت الوصول. يوفر ABAC مرونة أعلى مقارنة بـ RBAC، لكنه يتطلب سياسات أكثر تعقيداً وإدارة دقيقة للسمات.

- النماذج المعتمدة على العلاقات (Relationship-Based Access Models): تعتمد هذه النماذج على تحليل العلاقات بين الكيانات المختلفة داخل النظام، مثل المستخدمين، الأدوار، السياسات، والموارد. يتيح هذا الأسلوب تمثيل مسارات الوصول غير المباشرة واكتشاف سيناريوهات تصعيد الصلاحيات التي قد لا تكون واضحة عند استخدام النماذج التقليدية، مما يجعله مناسباً لتحليل البيانات السحابية المعقّدة.

ويُوضّح الشكل (3-1) المكونات الأساسية لعمليات التفويض والتحكم بالوصول في أنظمة إدارة الهوية والصلاحيات، مبيّناً دور السياسات، إدارة الأدوار، ومراجعات الوصول في ضبط الصلاحيات وتعزيز أمن الموارد السحابية.



الشكل 3-1 آليات التفويض والتحكم بالوصول في أنظمة إدارة الهوية والصلاحيات [8]

1.2.5 أخطاء إعداد IAM (IAM Misconfigurations) [7]

تُعد أخطاء إعداد أنظمة إدارة الهوية والصلاحيات (IAM Misconfigurations) من أخطر التهديدات الأمنية في البيئات السحابية، إذ غالباً ما تؤدي إلى تعريض الموارد أو البيانات الحساسة للوصول غير المصرح به. وتشير التقارير الأمنية إلى أن سوء التهيئة في سياسات IAM يُعد من الأسباب الرئيسية لحوادث الاختراق، نظراً لاعتماد المهاجمين على استغلال الصلاحيات الخاطئة بدلاً من البحث عن ثغرات تقنية معقدة.

ومن أكثر أخطاء إعداد IAM ما يلي:

- منح صلاحيات أكثر من اللازم (Over-Permission / Excessive Privileges): يحدث هذا الخطأ عند منح المستخدمين أو الخدمات صلاحيات تتجاوز متطلبات مهامهم الفعلية، مما يزيد من مساحة الهجوم ويتيح إمكانية استغلال هذه الصلاحيات في حال اختراق الحساب.
- الحسابات غير النشطة (Inactive Accounts): بقاء حسابات مستخدمين أو خدمات لم تعد قيد الاستخدام دون تعطيلها يشكل نقطة دخول خفية للمهاجمين، خاصة في حال عدم مراقبة هذه الحسابات أو تحديث بياناتها.
- سوء إعداد السياسات (Misconfigured Policies): يتضمن ذلك إنشاء سياسات وصول غير مقيّدة أو عامة، تسمح بالوصول إلى موارد متعددة دون ضوابط دقيقة، مما يسهل تجاوز آليات الحماية المعتمدة.
- غياب التنظيم الهرمي للأدوار والسياسات: عدم فصل الأدوار وتنظيمها بشكل هرمي واضح يؤدي إلى تعقيد إدارة الصلاحيات، ويزيد من احتمالية تداخل الامتيازات وصعوبة مراجعتها أو تدقيقها.

1.2.6 تأثير سوء إعداد IAM على الأمن السحابي [7]

لا يقتصر أثر أخطاء إعداد أنظمة إدارة الهوية والصلاحيات على الجوانب التنظيمية فقط، بل ينعكس بشكل مباشر على مستوى أمن البيئات السحابية ككل. إذ يؤدي سوء ضبط الصلاحيات أو غياب القيود المناسبة إلى إضعاف آليات التحكم بالوصول، مما يتيح للمهاجمين استغلال الحسابات أو الخدمات الحساسة بطرق غير مشروعة. وتشير الدراسات إلى أن نسبة كبيرة من الحوادث الأمنية في البيئات السحابية ترتبط بشكل

مباشر بأخطاء في سياسات IAM وإدارة الامتيازات (Catteddu & Hashizume et al., 2013)؛ (Hogben, 2009).

ومن أبرز التأثيرات الأمنية الناتجة عن سوء إعداد IAM ما يلي:

- اختراق البيانات (Data Breach): نتيجة منح صلاحيات وصول غير مقيّدة إلى موارد التخزين أو قواعد البيانات.
- تصعيد الصلاحيات (Privilege Escalation): حيث يستغل المهاجم صلاحيات محدودة للوصول إلى موارد ذات امتيازات أعلى.
- تعطيل الخدمات (Denial of Service): من خلال الوصول غير المصرّح به إلى إعدادات الشبكة أو الموارد الحرجة.

وبناءً على ذلك، فإن أي ضعف في تهيئة أنظمة IAM يمكن أن يهدد سرية البيانات، سلامة الموارد، وتوفر الخدمات السحابية، مما يجعل من الإدارة الدقيقة للصلاحيات عنصراً أساسياً في حماية البنية السحابية.

1.2.7 أهمية تحليل أنظمة IAM في البيئات السحابية [8]

مع التوسع المستمر في استخدام البيئات السحابية وتعقّد بنيتها التشغيلية، أصبحت أنظمة إدارة الهوية والصلاحيات أكثر تعقيداً من حيث العلاقات بين المستخدمين، الأدوار، السياسات، والموارد. هذا التعقيد يجعل من الصعب الاعتماد على المراجعة اليدوية لاكتشاف أخطاء التهيئة أو الصلاحيات غير الضرورية، خاصة في البيئات الديناميكية التي تشهد تغييرات مستمرة في الأدوار الوظيفية والخدمات.

يسهم تحليل أنظمة IAM في توفير رؤية شاملة لبنية الصلاحيات، من خلال فحص العلاقات البنيوية واكتشاف المسارات غير المباشرة للوصول، والتي قد تؤدي إلى تراكم الامتيازات (Privilege Creep) بمرور الوقت. كما يُعد التحليل الساكن (Static Analysis) أداة فعّالة لتقييم سياسات IAM قبل تطبيقها فعلياً، مما يسمح بالكشف المبكر عن الثغرات المحتملة وتقليل الاعتماد على المعالجة اللاحقة للحوادث الأمنية.

وتشير الدراسات الحديثة إلى أن اعتماد أدوات تحليل منهجية لأنظمة IAM يُعد ضرورة أساسية لضمان الالتزام بمبدأ أقل الامتيازات، وتحسين مستوى الأمان في البيئات السحابية المعقّدة، خاصة في ظل التوسع المستمر في الخدمات والموارد السحابية.

1.2.8 دور IAM في تعزيز أمن السحابة [5]

تعتمد معظم الخدمات السحابية الحديثة على الهوية الرقمية كعنصر أساسي لاتخاذ قرارات الوصول إلى الموارد. ومع تراجع فعالية نماذج الحماية التقليدية القائمة على حدود الشبكة، أصبحت IAM تمثل خط الدفاع الأول في حماية الأنظمة السحابية من الوصول غير المصرّح به.

يساهم التطبيق السليم لسياسات IAM في تقليل مساحة الهجوم (Attack Surface) من خلال تقييد الصلاحيات وفق مبدأ أقل الامتيازات، وضمان الفصل بين المهام، ومنع إساءة استخدام الحسابات ذات الامتيازات العالية. كما يتيح دمج IAM مع آليات تسجيل السجلات والمراقبة المستمرة تعزيز القدرة على تتبع الأنشطة المشبوهة، والكشف المبكر عن محاولات الاختراق أو إساءة استخدام الصلاحيات.

وبذلك، لا تقتصر وظيفة أنظمة IAM على إدارة المستخدمين والصلاحيات فحسب، بل تشكل مكوناً استراتيجياً في البنية الأمنية السحابية، يساهم في تحسين مستوى الحماية، وتعزيز الامتثال للسياسات والمعايير الأمنية، ودعم استمرارية الخدمات في البيئات السحابية الحديثة.

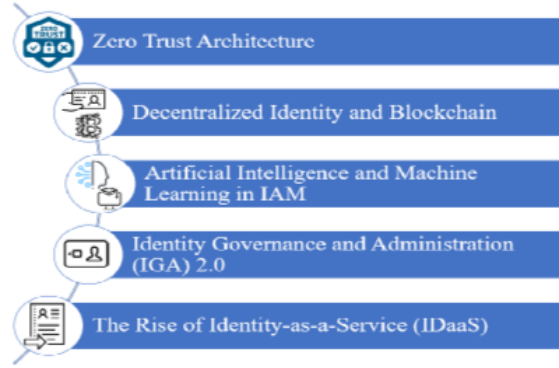
1.2.9 الاتجاهات المستقبلية في إدارة الهوية والصلاحيات (Future Trends in IAM) [8]

مع التوسع المتزايد في اعتماد الخدمات السحابية وتنامي التهديدات السيبرانية، تشهد أنظمة إدارة الهوية والصلاحيات تطوراً مستمراً لمواكبة متطلبات الأمن الحديثة وتحسين كفاءة الإدارة. وتشير الدراسات الحديثة إلى ظهور مجموعة من الاتجاهات التي تشكل الجيل القادم من أنظمة IAM، وتركز بشكل أساسي على تعزيز الأمان، تحسين تجربة المستخدم، وأتمتة العمليات الإدارية.

من أبرز هذه الاتجاهات:

- بنية الثقة الصفرية (Zero Trust Architecture): تعتمد على مبدأ عدم الثقة الضمنية بأي كيان داخل أو خارج الشبكة، وفرض التحقق المستمر من الهوية والصلاحيات قبل السماح بأي وصول إلى الموارد.
- الهوية اللامركزية وتقنيات سلسلة الكتل (Decentralized Identity and Blockchain): تهدف إلى منح المستخدمين سيطرة أكبر على هوياتهم الرقمية، وتقليل الاعتماد على مزودي الهوية المركزيين، مما يعزز الخصوصية ويحد من مخاطر الاختراق واسعة النطاق.
- الذكاء الاصطناعي وتعلم الآلة في IAM (Artificial Intelligence and Machine Learning in IAM): تُستخدم هذه التقنيات لتحليل أنماط السلوك، واكتشاف الأنشطة غير الطبيعية، ودعم اتخاذ قرارات وصول ديناميكية قائمة على المخاطر.
- حوكمة الهوية وإدارتها المتقدمة (Identity Governance and Administration – IGA 2.0): تركز على أتمتة عمليات مراجعة الصلاحيات، إدارة دورة حياة الهوية، وضمان الامتثال المستمر للسياسات والمعايير التنظيمية.
- الهوية كخدمة (Identity-as-a-Service – IDaaS): تعكس هذا الاتجاه انتقال أنظمة IAM إلى نماذج خدمية قائمة على السحابة، تتيح مرونة أعلى في النشر، وتخفف العبء الإداري عن المؤسسات.

ويُوضّح الشكل (4-1) أبرز الاتجاهات المستقبلية في أنظمة إدارة الهوية والصلاحيات، مبيّناً المسارات التي يتجه نحوها تطور IAM لمواجهة التحديات الأمنية المتزايدة في البيئات السحابية الحديثة.



الشكل 1-4 الاتجاهات المستقبلية في إدارة الهوية والصلاحيات [8]

1.3 أدوات تحليل IAM السحابية (IAM Analysis Tools) [8]

مع التوسّع المستمر في استخدام البيانات السحابية وتعقّد بنيتها التشغيلية، ظهرت أدوات تحليل IAM السحابية بوصفها حلاً متخصصاً تهدف إلى فحص سياسات الهوية والصلاحيات بشكل منهجي، والكشف المبكر عن المخاطر الأمنية قبل استغلالها. تعتمد هذه الأدوات على تحليل بنية IAM ككل، من خلال دراسة العلاقات المباشرة وغير المباشرة بين مكونات النظام، بما يتيح اكتشاف الصلاحيات الزائدة، تداخل الامتيازات، والمسارات غير المقصودة التي قد تؤدي إلى تصعيد الصلاحيات.

تشير الدراسات الحديثة إلى أن أدوات تحليل IAM التي تجمع بين التحليل البنيوي والنهج الاستباقي تُعد من أكثر الأساليب فاعلية في البيانات السحابية المعقّدة، حيث توفر رؤية شاملة لبنية الصلاحيات وتدعم تطبيق مبدأ أقل الامتيازات (Least Privilege) بشكل أكثر دقة، مما يساهم في تحسين مستوى الأمن وتقليل الاعتماد على الاستجابة اللاحقة للحوادث الأمنية.

1.4 سياسات إدارة الهوية والصلاحيات (IAM Policies) [8]

تُعد سياسات إدارة الهوية والصلاحيات (IAM Policies) المكوّن الأساسي الذي يُحدد كيفية التحكم بالوصول إلى الموارد في البيانات السحابية. تمثل هذه السياسات مجموعة من القواعد الرسمية التي تُعرّف بشكل دقيق العمليات المسموح بها أو الممنوعة على موارد محددة، وتُستخدم لضبط صلاحيات المستخدمين، الأدوار، والخدمات بطريقة منهجية وقابلة للتدقيق. تعتمد سياسات IAM على مبدأ المنع الافتراضي (Default Deny)، حيث يُرفض أي طلب وصول ما لم يتم السماح به صراحةً، مما يعزز مبدأ أقل الامتيازات ويحد من مخاطر إساءة استخدام الصلاحيات.

تنقسم سياسات IAM في البيانات السحابية الحديثة إلى عدة أنواع رئيسية، من أبرزها:

- السياسات المدمجة (Inline Policies): وهي سياسات تُربط مباشرةً بمستخدم، مجموعة، أو دور محدد، وتكون مخصصة لهذا الكيان فقط. تُستخدم عادةً عند الحاجة إلى صلاحيات خاصة لا يُراد مشاركتها مع كيانات أخرى، وتُحذف تلقائياً عند حذف الكيان المرتبط بها.

- السياسات المُدارة (Managed Policies): سياسات قابلة لإعادة الاستخدام يمكن ربطها بعدة مستخدمين أو أدوار في الوقت نفسه. تسهّل هذه السياسات عملية الإدارة، حيث إن أي تعديل عليها ينعكس مباشرة على جميع الكيانات المرتبطة بها، مما يضمن الاتساق في تطبيق الصلاحيات.
 - حدود الصلاحيات (Permissions Boundaries): تُستخدم كطبقة إضافية لتقييد الحد الأقصى للصلاحيات التي يمكن أن يحصل عليها مستخدم أو دور، حتى في حال وجود سياسات أخرى تمنحه صلاحيات أوسع. تُعد هذه الآلية مهمة في سيناريوهات التفويض الإداري ومنع تصعيد الصلاحيات غير المقصود.
 - سياسات التحكم على مستوى المؤسسة (Service Control Policies – SCPs): تُطبّق على مستوى الحسابات أو الوحدات التنظيمية، وتهدف إلى فرض قيود عامة تحدد ما هو مسموح أو غير مسموح ضمن النطاق المؤسسي، دون منح صلاحيات مباشرة بحد ذاتها.
 - السياسات المعتمدة على الموارد (Resource-Based Policies): تُربط مباشرةً بالموارد السحابية نفسها، مثل خدمات التخزين أو الرسائل، وتُستخدم غالباً في سيناريوهات الوصول بين حسابات مختلفة، حيث يتم تحديد من يمكنه الوصول إلى المورد وتحت أي شروط.
- يساهم هذا التنوع في سياسات IAM في توفير مرونة عالية لإدارة الصلاحيات، إلا أنه في الوقت ذاته يزيد من تعقيد البنية الأمنية، مما يجعل سوء التهيئة أو التداخل بين السياسات سبباً رئيسياً لظهور الثغرات الأمنية في البيئات السحابية.

1.5 المصائد الأمنية (Honeypots)

تُعد المصائد الأمنية (Honeypots) أدوات فعّالة في مجال أمن المعلومات، تهدف إلى استدراج المهاجمين وكشف أساليبهم دون تعريض الأنظمة الحقيقية للخطر.

1.5.1 تعريف المصائد الأمنية [9]

المصيدة الأمنية هي نظام معلوماتي مصمم ليبدو كهدف للمهاجم، لكنه في الواقع أداة مراقبة تهدف إلى دراسة تصرفات المهاجم وتحليل تهديداته. يتم نشر هذه الأنظمة بشكل منفصل أو ضمن بيئة حوسبة سحابية لمحاكاة خدمات وتطبيقات حقيقية مثل SSH أو HTTP، بحيث يتم تسجيل أي تفاعل مشبوه معها. الهدف من المصائد لا يقتصر فقط على اكتشاف الهجمات، بل يتعداه إلى:

- تحليل سلوك المهاجمين وتحديد أدواتهم.
- جمع بيانات استخبارات التهديد.
- تحسين آليات الدفاع المستقبلية.

1.5.2 أنواع المصائد الأمنية [10]

تنقسم المصائد الأمنية إلى ثلاثة أنواع رئيسية حسب مستوى التفاعل:

- **Low-Interaction Honeypots**: تحاكي الخدمات بشكل بسيط دون تنفيذ فعلي لها و تُستخدم لتسجيل محاولات الهجوم السريعة ومنخفضة التعقيد.
- **Medium-Interaction Honeypots**: توفر تفاعل أعمق مع المهاجم، ما يسمح بجمع المزيد من البيانات حول الأوامر والأنشطة.
- **High-Interaction Honeypots**: أنظمة حقيقية تُنشر لمراقبة سلوك الهجوم الكامل، وتتيح تحليلاً دقيقاً لتقنيات المهاجمين، لكنها تتطلب عزلاً محكماً بسبب خطورتها العالية.

1.5.3 دور المصائد الأمنية في البيئات السحابية [11]

في بيئة الحوسبة السحابية، تُستخدم المصائد الأمنية كوسيلة فعّالة لرصد التهديدات المستمرة والمتقدمة (Advanced Persistent Threats - APTs). يمكن نشرها في أماكن استراتيجية ضمن بنية الخدمة السحابية، مثل الشبكات الافتراضية (VPCs)، لتحاكي نقاط ضعف واقعية وتسجيل الهجمات. تشمل تطبيقات honeypots السحابية:

- كشف الأنشطة الغير المصرح بها داخل بيئة IAM.
- تحليل سلوك المهاجم عند محاولته التسلل إلى موارد البنية التحتية.

1.5.4 التحديات والمخاطر المرتبطة باستخدام Honeypots [10]

- رغم فوائد المصائد الأمنية، إلا أن استخدامها ليس خالياً من التحديات، خصوصاً في البيئة السحابية، ومن أبرزها:
- خطر الاستخدام العكسي (Backdoor): إذا تمكن المهاجم من السيطرة على المصيدة، قد يستخدمها كنقطة انطلاق لهجمات أخرى.
- كشف المصيدة (Detection): المهاجمون المتقدمون يمكنهم أحياناً التعرف على خصائص honeypots وتجنبها.
- تكلفة الإدارة: خاصة في حالات high-interaction honeypots التي تتطلب موارد بشرية وتقنية عالية.
- لذلك يجب نشر المصائد ضمن بيئة معزولة بشكل جيد، وباستخدام أدوات مراقبة متقدمة تضمن عدم تحول المصيدة إلى نقطة ضعف.

1.5.5 المصائد الأمنية القائمة على السحابة (Cloud-Based Honeypots) [11]

تُعد المصائد الأمنية القائمة على السحابة (Cloud-Based Honeypots) تطويراً للمصائد التقليدية، حيث تستفيد من خصائص الحوسبة السحابية مثل سهولة النشر، المرونة، وقابلية التوسع. على عكس المصائد التقليدية التي تعمل في بيئات محلية محدودة، يمكن نشر المصائد السحابية بسرعة داخل بيئات افتراضية تحاكي خدمات سحابية حقيقية مثل التخزين السحابي، واجهات البرمجة، أو أنظمة إدارة الهوية والصلاحيات.

تتيح هذه المصادد مراقبة محاولات الهجوم وتسجيلها دون التأثير على أنظمة الإنتاج الفعلية، كما يمكن عزلها أو حذفها بسهولة عند الحاجة. وتشير الدراسات إلى أن المصادد السحابية تُعد أكثر ملاءمة للبيئات الحديثة، خاصة في البنى التي تعتمد على النشر الآلي والخدمات السحابية، لما توفره من قدرة أفضل على رصد الهجمات وتحليلها بشكل آمن وفعال.

يوضح الجدول (1-1) الفروقات الأساسية بين المصادد التقليدية والمصادد القائمة على السحابة، إذ توفر المصيدة السحابية قدرة أعلى في اكتشاف الهجمات المتقدمة، خاصة تلك التي تستهدف أنظمة IAM والبنى السحابية.

جدول 1-1 مقارنة بين المصادد السحابية والتقليدية

وجه المقارنة	المصيدة التقليدية	المصيدة السحابية
بيئة التشغيل	خوادم محلية أو شبكات داخلية	بيئات سحابية افتراضية
قابلية التوسع	محدودة وتحتاج تدخل يدوي	عالية ومرنة ديناميكياً
العزل الأمني	عزل فيزيائي أو منطقي محدود	عزل افتراضي متقدم
سهولة النشر	بطيئة نسبياً	سريعة وآلية
التكيف مع الهجمات	ثابتة	قابلة لإعادة التهيئة تلقائياً
التكامل مع التحليل	محدود	تكامل مباشر مع أنظمة التحليل والسجلات
ملاءمة البيانات الحديثة	منخفضة	عالية جداً

1.6 تصنيف المستخدمين (User Classification)

في أنظمة الأمن السيبراني، من الضروري فهم طبيعة وتصنيفات المستخدمين الذين يتفاعلون مع النظام، سواء أكانوا شرعيين أم خبيثين. يُعد تصنيف المستخدمين أداة أساسية في تحليل السلوك، الكشف عن التهديدات، وبناء آليات دفاعية فعالة تعتمد على فهم النمط السلوكي لكل فئة.

1.6.1 تعريف المستخدم الشرعي (Legitimate User) [8]

هو الشخص أو الكيان الذي يمتلك صلاحيات موثقة للوصول إلى موارد النظام أو الشبكة، وغالباً ما يُحدد ذلك من خلال أنظمة إدارة الهوية والصلاحيات (IAM). يُفترض بهذا المستخدم أن يتصرف ضمن الحدود المسموح بها، وفقاً للدور (Role) أو المهمة التي ينتمي إليها ضمن البنية المؤسسية.

1.6.2 تعريف المهاجم (Attacker) [5]

هو كيان (فرد أو برنامج أو مجموعة) يسعى إلى اختراق النظام، أو تجاوز آليات الحماية الأمنية بهدف الوصول غير المشروع إلى المعلومات أو تعطيل الخدمات.

يمكن أن يتخذ المهاجم عدة أشكال:

- مهاجم خارجي (External Attacker): لا يمتلك صلاحيات، ويحاول التسلل من خارج النظام.
- مهاجم داخلي (Insider Threat): يملك صلاحيات شرعية لكنه يسيء استخدامها عن قصد أو بدون قصد.

يُعد فهم طبيعة المهاجم ضرورياً لتصميم سياسات دفاع متقدمة تتضمن التحقق المتعدد الطبقات، والتسجيل الذكي للسلوكيات، والاستجابة المبكرة للهجمات.

1.7 السجلات (Logs)

تُعد أنظمة تسجيل السجلات جزءاً أساسياً من أي بنية أمنية، حيث تسجل كل الأنشطة التي تحدث في النظام بهدف الرجوع إليها لاحقاً في التحقيقات أو التحليل الأمني.

1.7.1 تعريف السجلات [11]

هي ملفات أو هياكل بيانات تقوم بتوثيق الأحداث والأنشطة التي تحدث داخل الأنظمة والشبكات. تلعب دوراً محورياً في مراقبة النظام، الكشف عن الهجمات، وتحليل الحوادث الأمنية، حيث تُمكن من تتبع نشاط المستخدمين والتطبيقات واكتشاف السلوكيات غير الطبيعية.

1.7.2 نظام تسجيل السجلات (Log Recording Systems) [11]

هو إطار تقني يُستخدم لتوليد، جمع، وتخزين السجلات الناتجة عن الأنظمة والتطبيقات والبنى التحتية. تشمل السجلات بيانات مثل:

- محاولات الدخول
- الأوامر المنفذة
- التنبيهات الأمنية

وتُعد هذه الأنظمة عنصراً محورياً في مراقبة الأنشطة والكشف المبكر عن التهديدات.

1.7.3 مكونات نظام تسجيل السجلات [11]

يتكون نظام السجلات من عنصرين أساسيين:

- العميل (Log Client): وهو الكيان الذي يُنتج السجلات، مثل نظام التشغيل، أو التطبيق، أو المصيدة الأمنية (Honeypot). يقوم بإرسال السجلات إلى الوجهة المحددة.
 - الخادم (Log Server): يُستقبل السجلات ويخزنها.
- ويتم نقل السجلات باستخدام بروتوكولات قياسية مثل Syslog أو تنسيقات حديثة مثل JSON.

1.7.4 آلية تبادل السجلات (Log Transmission Mechanism) [11]

يتم تبادل السجلات بين العناصر المختلفة في نظام التسجيل باستخدام بروتوكولات نقل مخصصة تهدف إلى ضمان السرعة، الموثوقية، والأمان. من أشهر هذه البروتوكولات:

- Syslog (RFC 5424): بروتوكول نصي بسيط يُستخدم على نطاق واسع في أنظمة UNIX/Linux لإرسال السجلات إلى خادم مركزي. تُستخدم تقنيات التشفير (مثل TLS/SSL) لضمان سرية السجلات أثناء النقل، بينما تُستخدم آليات التحقق من السلامة (مثل SHA-256) لضمان عدم التلاعب بها. كما تُطبق سياسات للتحكم بالوصول لضمان ألا يتمكن سوى الكيانات المصرّح لها من إرسال أو استقبال السجلات.

قدّم هذا الفصل خلفية نظرية توضّح كيف أصبحت الهوية الرقمية محور التحكم بالوصول في البيئات السحابية، ولماذا تُعد أخطاء إعداد IAM من أكثر مصادر المخاطر شيوعاً وتأثيراً. كما تناول الفصل دور المصادد الأمنية في استدراج الهجمات ورصدها بشكل آمن، وأهمية السجلات في بناء رؤية تحليلية دقيقة للسلوكيات والأنشطة. وبذلك تم استعراض المفاهيم الأساسية التي يعتمد عليها المشروع نظرياً، والتي تُعد ركائز داعمة لفهم التقنيات المستخدمة وتبرير الاختيارات الأمنية في تصميم النظام المقترح، بما يسهم في كشف السلوك الضار وتعزيز أمن البيئة السحابية.

الفصل الثاني

الدراسات السابقة

2 الفصل الثاني - الدراسات السابقة

يركّز هذا الفصل على استعراض وتحليل الدراسات والأبحاث الحديثة التي تناولت أمن الحوسبة السحابية، مع التركيز على أنظمة إدارة الهوية والصلاحيات (IAM)، أتمتة الأمن السحابي، واستخدام المصائد الأمنية (Honeypots) في كشف التهديدات. يهدف هذا الاستعراض إلى إبراز الاتجاهات البحثية السائدة، وتحديد نقاط القوة والقصور في الحلول المقترحة، وصولاً إلى توضيح الفجوة البحثية التي يسعى هذا المشروع إلى معالجتها من خلال الدمج بين تحليل IAM والمصائد الأمنية ضمن إطار تحليلي موحد.

2.1 الدراسات السابقة

Cloud Security Alliance – Top Threats to Cloud Computing: Deep Dive [12] (2025)

يركّز هذا التقرير الصناعي على تحليل أبرز التهديدات الأمنية في البيئات السحابية اعتماداً على ثماني حوادث واقعية وقعت بين عامي 2023 و2024. وضّح التقرير إلى أن سوء تكوين سياسات إدارة الهوية والصلاحيات (IAM Misconfigurations) وفشل الحوكمة الأمنية يمثلان المصدر الأساسي لغالبية الحوادث. أظهرت النتائج أن تعطيل المصادقة متعددة العوامل، ومنح الصلاحيات المفرطة، وغياب مبدأ أقل الامتيازات كانت عوامل مشتركة في معظم الاختراقات. تبرز أهمية هذه الدراسة في تأكيدها على الحاجة إلى التحليل الوقائي المؤتمت لسياسات IAM، لكنها لا تتناول الجوانب التنفيذية أو التكامل مع أدوات كشف هجومية مثل المصائد الأمنية.

Microsoft – State of Multicloud Security Report 2024 [13]

يستعرض هذا التقرير واقع أمن البيئات متعددة السُحب من خلال تحليل بيانات ضخمة مأخوذة من منصات AWS و Azure و GCP. ويسلط الضوء على تضخم الهويات، وتراكم الصلاحيات (Permission Creep)، وازدياد عدد المسارات القابلة للاستغلال داخل أنظمة IAM. تشير النتائج إلى أن نسبة صغيرة جداً من الصلاحيات تُستخدم فعلياً، في حين يشكل الباقي سطح هجوم غير ضروري. تبرز أهمية التقرير في تقديم مؤشرات كمية حديثة حول مخاطر IAM، لكنه يظل تقريراً وصفيّاً يفتقر إلى نماذج تحليل هجومية أو تكامل مع آليات خداع مثل Honeypots.

Cloud Identity and Access Management (IAM) Automation [14] (2025)

تناقش هذه الدراسة التحول من إدارة الهوية التقليدية إلى أنظمة IAM المؤتمتة في البيئات السحابية الحديثة. تؤكد الورقة أن الأتمتة تساهم في تقليل الأخطاء البشرية، وتسريع عمليات منح وسحب الصلاحيات، وتحسين الامتثال الأمني. تعتمد الدراسة على مفاهيم مثل Infrastructure as Code والتكامل مع واجهات البرمجة السحابية، وتشير إلى أهمية دمج IAM المؤتمت مع أنظمة مراقبة مثل SIEM. تدعم هذه

الدراسة الأساس النظري لاعتماد التحليل الآلي في المشروع، إلا أنها لا تقدّم توصيفاً لكيفية اكتشاف الهجمات أو ربط التحليل بسلوك المهاجمين.

Fixing Privilege Escalations in Cloud Access Control with MaxSAT and Graph Neural Networks(2023) [15]

تعالج هذه الدراسة مشكلة تصعيد الصلاحيات الناتج عن سوء إعداد سياسات IAM في البيئات السحابية، مع التركيز على إصلاح هذه الأخطاء وليس فقط اكتشافها. تفتّح الورقة أداة جديدة تُدعى IAMPERE قادرة على توليد تعديلات شبه مثالية (Approximately Minimal Patches) لمعالجة عدد أكبر من أنماط تصعيد الصلاحيات مقارنة بالأدوات السابقة.

تعتمد المنهجية على نمذجة المشكلة باستخدام MaxSAT، مع الاستعانة بالشبكات العصبية البيانية (GNN) لتقليل مساحة البحث وتحسين القابلية للتوسع. تُظهر النتائج تفوق الأداة المقترحة من حيث عدد الحالات المُعالجة وحجم التعديلات المطلوبة. تمثل هذه الدراسة مرجعاً مهماً لدعم التحليل البنيوي لمسارات تصعيد الصلاحيات في IAM، لكنها لا تربط النتائج بسلوك هجومي فعلي.

Cloud Security Automation Through Symmetry: Threat Detection and Response – Pitkar(2025) [16]

تطرح هذه الدراسة إطاراً متقدماً لأتمتة الأمن السحابي قائماً على تحقيق التوازن بين الكشف الآلي للتهديدات والاستجابة التلقائية لها. تقترح بنية متعددة الطبقات تدمج أنظمة SIEM و SOAR و XDR مع تقنيات الذكاء الاصطناعي، بهدف تقليل زمن الاستجابة وتحسين دقة الكشف. تبرز أهمية الدراسة في تقديم نموذج معماري متكامل للأتمتة الأمنية، إلا أن تركيزها يبقى عاماً ولا يتناول تحليل IAM بعمق أو دمج مع بيانات خداع هجومية مثل المصائد الأمنية.

Cyber Threat Detection with Honeypots – Valiyev(2025) [17]

تمثل هذه الدراسة نموذجاً تطبيقياً لنشر المصائد الأمنية باستخدام منصة T-Pot المفتوحة المصدر لرصد الهجمات السيبرانية في الزمن الحقيقي. اعتمدت الورقة على جمع وتحليل بيانات الهجمات عبر ELK Stack، وتمكنت من توثيق أنماط هجومية واقعية وثغرات شائعة. تبرز قوة الدراسة في الجانب التطبيقي العملي، إلا أنها تفتقر إلى الأتمتة التحليلية، ولا تتضمن أي تكامل مع أنظمة IAM أو آليات ربط بين سلوك المهاجم والصلاحيات المستهدفة.

Advancing Cybersecurity with Honeypots and Deception Strategies – Pitkar (2025) [18]

تقدّم هذه الدراسة مقارنة تجريبية بين عدة أنظمة Honeypot مفتوحة المصدر، مع تقييم أدائها من حيث نطاق الكشف، الموثوقية، وقابلية التوسع. توصلت النتائج إلى تفوّق بعض المصائد مثل Cowrie

Dionaea، وأكدت أهمية دمج المصادد مع أنظمة أمنية أخرى لتحسين فعالية الرصد. تساهم هذه الدراسة في ترسيخ الدور الدفاعي للمصادد الأمنية، لكنها لا تربط نتائج الهجمات بتحليل الهوية أو مسارات تصعيد الصلاحيات داخل أنظمة IAM.

SkyEye: When Your Vision Reaches Beyond IAM Boundary Scope in AWS Cloud(2025) [19]

تعد هذه الدراسة من أبرز الأبحاث المتقدمة في تحليل سوء تكوين IAM داخل بيئة AWS. تقترح إطاراً تحليلياً جديداً يعتمد على التعداد التعاوني متعدد الهويات لاكتشاف مسارات تصعيد الصلاحيات غير المباشرة. أثبتت النتائج قدرة النظام على كشف ثغرات لم تتمكن أدوات أخرى من اكتشافها. تمثل هذه الدراسة الأساس العلمي لفكرة IAM Analyzer، لكنها تركز على التحليل الهجومي فقط، دون ربط النتائج بسلوك هجومي فعلي أو دمجها مع مصادد أمنية أو أنظمة استجابة.

Dynamic Honeypot Deployment for Enhanced Cybersecurity – Aljuneidi (2025) [20]

تقترح هذه الدراسة إطاراً لمصيدة أمنية ديناميكية تهدف إلى معالجة محدودية المصادد الثابتة التي قد يتم اكتشافها من قبل المهاجمين. تعتمد المنهجية على تغيير الهوية الشبكية للمصيدة تلقائياً (مثل عنوان IP و MAC واسم المضيف ومفاتيح التشفير) بهدف زيادة صعوبة اكتشافها. تم دمج أدوات مفتوحة المصدر مثل Snort و OpenCanary و Elastic Stack ضمن نظام تفاعلي يتكيف مع التهديدات. أظهرت نتائج التقييم تحسناً واضحاً في كفاءة الكشف وتقليل الإنذارات الكاذبة مقارنة بالمصادد التقليدية لكنها لا تتناول أنظمة IAM أو تحليل الصلاحيات.

CIS Benchmarks: Enhancing Security Configurations in Multi-Cloud Infrastructures(2024) [21]

تركز هذه الدراسة على دور CIS Benchmarks في تحسين إعدادات الأمان ضمن البيئات متعددة السحب، من خلال توفير مجموعة من أفضل الممارسات القياسية لتقليل المخاطر وتعزيز الامتثال الأمني. توضح الورقة كيف يمكن استخدام هذه المعايير لتوحيد سياسات الأمان، والحد من أخطاء التهيئة الشائعة، خاصة في البيئات التي تجمع بين مزودين سحابيين مختلفين. كما تناقش التحديات المرتبطة بتطبيق هذه المعايير في البيئات المعقدة، وتؤكد على أهمية الأتمتة في فرض الإعدادات الأمنية وتقليل الأخطاء البشرية.

2.2 مقارنة بين المشروع والدراسات السابقة

بعد استعراض الدراسات والأبحاث الحديثة في مجال أمن الحوسبة السحابية، اتضح أن معظم الأعمال السابقة ركزت على محور واحد من محاور الأمن السحابي، مثل تحليل أنظمة إدارة الهوية والصلاحيات (IAM)، أو أتمتة الضبط الأمني، أو استخدام المصائد الأمنية (Honeypots) لرصد الهجمات. وعلى الرغم من القيمة العلمية والتطبيقية لهذه الدراسات، إلا أن كلاً منها عالج المشكلة من زاوية جزئية دون تقديم إطار متكامل يجمع بين التحليل البنيوي للصلاحيات والسلوك الهجومي الفعلي.

تبين المقارنة أن الدراسات المعنية بـ IAM ركزت بشكل أساسي على اكتشاف أو إصلاح أخطاء التهيئة ومسارات تصعيد الصلاحيات، غالباً باستخدام أساليب تحليل ساكنة أو نماذج رسم بياني، لكنها لم تربط نتائج التحليل بمحاولات هجوم حقيقية أو سلوك المهاجم داخل البيئة السحابية. في المقابل، ركزت دراسات المصائد الأمنية على جمع بيانات الهجمات وتحليلها، إلا أنها تعاملت مع المصيدة كنظام معزول عن سياق الصلاحيات والهوية، دون الاستفادة من معلومات IAM لفهم دوافع الهجوم أو الأهداف المستهدفة.

أما التقارير الصناعية والمعايير الأمنية، فقد ساهمت في إبراز حجم المخاطر المرتبطة بسوء إعداد IAM وتضخم الصلاحيات، وقدمت إرشادات عامة لتحسين الضبط الأمني.

ينطلق المشروع المقترح من هذه الفجوة البحثية، حيث يهدف إلى الدمج بين تحليل IAM الساكن والمصائد الأمنية ضمن بيئة سحابية محاكية، بحيث يتم ربط أخطاء التهيئة ومسارات تصعيد الصلاحيات بسلوك هجومي فعلي يتم رصده وتحليله. هذا التكامل يتيح فهماً أعمق لكيفية استغلال الثغرات، ويقدم قيمة مضافة مقارنة بالدراسات السابقة التي عالجت كل عنصر بشكل منفصل.

يوضح الجدول (1-2) مقارنة تحليلية بين المشروع المقترح والدراسات السابقة، اعتماداً على مجموعة من المعايير البحثية الشائعة في مراجعات الأدبيات العلمية. تشمل هذه المعايير عنوان الدراسة، الهدف الرئيسي، النتائج الأساسية، نقاط القوة المنهجية، نقاط الضعف أو القيود، إضافة إلى علاقة كل دراسة بالمشروع الحالي. مما يبرز بوضوح الإضافة العلمية والتطبيقية التي يقدمها هذا البحث.

جدول 1-2 المقارنة بين الدراسات

العنوان	الهدف الرئيسي	النتائج	نقاط القوة	نقاط الضعف	علاقة الورقة بالمشروع
Cloud Security Alliance – Top Threats to Cloud Computing: Deep Dive (2025)	تحديد أبرز التهديدات الأمنية في البيئات السحابية اعتمادًا على حوادث واقعية	أثبت أن سوء إعداد IAM وفشل الحوكمة يمثلان السبب الرئيسي لغالبية الاختراقات السحابية	يستند إلى حوادث حقيقية ويقدم رؤية شاملة على مستوى الصناعة	تقرير وصفي لا يقدم نماذج تحليل أو حلول تنفيذية	يدعم الدافع البحثي للمشروع ويبرز التركيز على IAM Misconfigurations
Microsoft – State of Multicloud Security Report (2024)	تحليل وضع الأمن في البيئات متعددة السحب	كشف تضخم الهويات وتراكم الصلاحيات ووجود مسارات وصول غير ضرورية	بيانات كمية واسعة من بيانات حقيقية متعددة السحب	لا يقدم آليات تحليل بنوية أو ربط بالسلوك الهجومي	يبرز مشكلة Privilege Creep التي يستهدفها المشروع بالتحليل البنوي
Cloud Identity and Access Management (IAM) Automation (2025)	دراسة أثر أتمتة IAM في البيئات السحابية الحديثة	أظهرت أن الأتمتة تقلل الأخطاء البشرية وتحسن الامتثال الأمني	تركيز واضح على الأتمتة والتكامل مع الأنظمة السحابية	غياب تحليل مسارات تصعيد الصلاحيات أو سلوك المهاجم	تدعم اعتماد التحليل الآلي داخل المشروع
Fixing Privilege Escalations in Cloud Access Control with MaxSAT and GNNs (2023)	إصلاح مسارات تصعيد الصلاحيات الناتجة عن سوء إعداد IAM	أثبتت فاعلية أداة IAMPERE في توليد تعديلات شبه مثالية للسياسات	تحليل رسمي متقدم باستخدام MaxSAT وGNN	تركيز على الإصلاح دون ربط بسلوك هجومي أو بيئة خداع	يدعم التحليل البنوي لمسارات التصعيد التي يعتمدها المشروع
Cloud Security Automation Through Symmetry – Pitkar (2025)	أتمتة كشف التهديدات والاستجابة في البيئات السحابية	تقليل زمن الاستجابة وتحسين دقة الكشف	نموذج معماري متكامل للأتمتة الأمنية	معالجة عامة دون تركيز على IAM أو Honeypots	يبرز أهمية الأتمتة التي يعتمدها المشروع جزئيًا
Cyber Threat Detection with Honeypots – Valiyev (2025)	استخدام المصائد الأمنية لرصد الهجمات في الزمن الحقيقي	توثيق أنماط هجومية واقعية باستخدام ELK Stack	تطبيق عملي واقعي للمصائد الأمنية	عدم وجود أتمتة تحليلية أو تكامل مع IAM	يدعم الجانب التطبيقي للمصيدة في المشروع
Advancing Cybersecurity with Honeypots	تقييم أنظمة Honeypot وتقنيات الخداع	تفوق مصائد محددة وتحسين فعالية الرصد	مقارنة تجريبية منهجية بين عدة أدوات	غياب الربط بين الهجوم والصلاحيات أو IAM	يرسخ الدور الدفاعي للمصائد المستخدمة في المشروع

					and Deception Strategies – Pitkar (2025)
يمثل الأساس العلمي لمفهوم IAM Analyzer في المشروع	غياب الربط بسلوك هجومي فعلي	تحليل تعاوني متقدم لمسارات التصعيد	كشف ثغرات لم تتمكن الأدوات التقليدية من اكتشافها	اكتشاف مسارات تصعيد الصلاحيات غير المباشرة في AWS IAM	SkyEye: Beyond IAM Boundary Scope in AWS Cloud (2025)
يدعم فكرة المصيدة المتقدمة المستخدمة في المشروع	IAM لا يتناول أو تحليل الصلاحيات	إطار خداع متكيف وقابل للتوسع	زيادة زمن الكشف وتقليل الإنذارات الكاذبة	تطوير مصيدة ديناميكية تتجنب اكتشاف المهاجم	Dynamic Honeypot Deployment for Enhanced Cybersecurity – Aljuneidi (2025)
تشكل مرجعاً داعماً لضبط الإعدادات وليس للتحليل	لا تكتشف المسارات الهجومية أو السلوك الضار	معايير صناعية معتمدة وقابلة للأتمتة	تقليل أخطاء التهئية وتعزيز الامتثال	تحسين إعدادات الأمان عبر معايير قياسية	CIS Benchmarks: Enhancing Security Configurations in Multi-Cloud (2024)

تُظهر المقارنة أن الدراسات السابقة تناولت جوانب متفرقة من المشكلة، إما من منظور تحليل أنظمة إدارة الهوية والصلاحيات (IAM)، أو من زاوية استخدام المصائد الأمنية، أو ضمن أطر عامة لأتمتة الأمن السحابي، دون تقديم إطار موحد يربط بين تحليل الصلاحيات وسلوك المهاجم الفعلي داخل البيئة السحابية. وانطلاقاً من هذه الفجوة البحثية، يأتي المشروع المقترح ليقدم مقارنة تكاملية تقوم على الدمج بين تحليل IAM الساكن والمصائد الأمنية ضمن بيئة سحابية تجريبية متكاملة، بما يتيح فهماً أعمق لكيفية استغلال الثغرات وربطها بالسلوك الهجومي الحقيقي.

2.3 الإطار التحليلي المعتمد في المشروع

تم الاعتماد على إطار تحليلي مركب يجمع بين تحليل أنظمة إدارة الهوية والصلاحيات (IAM) والتحليل العملي للسلوك الهجومي داخل بيئة سحابية معزولة. يقوم هذا الإطار على تحليل بنيوي ساكن لسياسات IAM والعلاقات بين المستخدمين، الأدوار، السياسات، والموارد، باستخدام تمثيل بياني يسمح باكتشاف مسارات الوصول غير المباشرة وسيناريوهات تصعيد الصلاحيات المحتملة. يهدف هذا التحليل إلى فهم البنية الداخلية للصلاحيات قبل حدوث أي هجوم فعلي، وتحديد نقاط الضعف الناتجة عن سوء التهئية أو تراكم الامتيازات.

بالتوازي مع ذلك، يدمج المشروع المصائد الأمنية السحابية كجزء من نفس الإطار التحليلي، حيث تُستخدم المصيدة لرصد السلوك الهجومي الحقيقي داخل بيئة تحاكي بنية سحابية واقعية دون التأثير على أنظمة

الإنتاج. يتم تسجيل وتحليل تفاعلات المهاجمين مع المصيدة وربطها بنتائج تحليل IAM، مما يتيح فهماً أعمق للعلاقة بين أخطاء الصلاحيات والأهداف التي يسعى المهاجمون للوصول إليها.

قدّم هذا الفصل تحليلاً منهجياً للدراسات والأعمال البحثية الحديثة المرتبطة بأمن الحوسبة السحابية، مع التركيز على أنظمة إدارة الهوية والصلاحيات، أتمتة الأمن السحابي، وتقنيات المصادد الأمنية. أتاح هذا التحليل تحديد الاتجاهات البحثية المعتمدة في معالجة مشكلات سوء إعداد IAM، وآليات اكتشاف مسارات تصعيد الصلاحيات، إضافة إلى الأساليب المستخدمة في رصد السلوك الهجومي عبر المصادد الأمنية.

الفصل الثالث

منهجية العمل والتصميم

3 الفصل الثالث – منهجية العمل والتصميم

يقدم هذا الفصل وصفاً تفصيلياً للجوانب العملية والتقنية المعتمدة في تصميم وبناء النظام المقترح، حيث يركز على تحليل سياسات إدارة الهوية والصلاحيات (IAM Analyzer) ودمجها مع مصيدة أمنية (Honeypot) ضمن بيئة حوسبة سحابية من نمط البنية التحتية كخدمة (IaaS).

3.1 منصة Openstack

تعدّ OpenStack منصة حوسبة سحابية مفتوحة المصدر تُستخدم لبناء وإدارة بيئات الحوسبة السحابية العامة والخاصة، وتوفّر إمكانيات متقدمة لتقديم خدمات البنية التحتية كخدمة (Infrastructure as a Service – IaaS). تعتمد المنصة على مجموعة من الخدمات المترابطة التي تُمكن من إدارة الموارد الافتراضية، بما يشمل موارد الحوسبة، والشبكات، والتخزين، إضافةً إلى خدمات إدارة الهوية والصلاحيات.

استُخدمت OpenStack كقاعدة تقنية لبناء البيئة السحابية المستضافة لمكونات النظام الأمني، مثل أداة تحليل سياسات إدارة الهوية والصلاحيات (IAM Analyzer) والمصيدة الأمنية (Honeypot)، حيث توفّر بيئة قابلة للتوسع والتحكم، بما يسمح بمحاكاة سيناريوهات واقعية لسلوك المستخدمين ضمن بيئة سحابية معزولة وأمنة.

3.1.1 المكونات الأساسية في OpenStack

تتكوّن منصة OpenStack من مجموعة من الوحدات الأساسية التي تعمل معاً ضمن بنية متكاملة لإدارة موارد الحوسبة السحابية، ومن أبرز هذه الوحدات:

- Nova: مسؤولة عن إدارة موارد الحوسبة، وإنشاء وتشغيل الأجهزة الافتراضية.
 - Neutron: تُستخدم لإدارة الشبكات الافتراضية، والتحكم في آليات الاتصال بين الأجهزة والخدمات.
 - Keystone: تُعنى بإدارة الهوية، والمصادقة، والصلاحيات، وتمثّل الأساس المفاهيمي لنظام إدارة الهوية والصلاحيات (IAM).
 - Glance: توفّر خدمة إدارة صور الأنظمة الافتراضية المستخدمة في إنشاء الأجهزة.
 - Horizon: واجهة رسومية تفاعلية تتيح إدارة موارد OpenStack ومكوناتها بشكل مركزي.
- تساهم هذه الوحدات في تحقيق فصلٍ واضحٍ بين مكونات النظام من خلال تشغيلها ضمن أجهزة افتراضية مستقلة، ممّا يعزّز مبدأ العزل، ويزيد من مستوى التحكم والأمان داخل البيئة السحابية.

3.1.2 فوائد استخدام OpenStack

يُتيح استخدام OpenStack التحكم الكامل في البنية التحتية السحابية دون الاعتماد على مزودي خدمات سحابية خارجيين، مما يسمح بإنشاء بيئة افتراضية معزولة ومُدارة ذاتياً. يوفّر ذلك إمكانية تخصيص موارد مستقلة لكل مكون من مكونات النظام الأمني، وتشغيلها ضمن بنية سحابية تحاكي بيئات التشغيل الحقيقية.

تُمكن هذه البيئة من اختبار سياسات إدارة الهوية والصلاحيات وتحليل نتائج الضبط غير الصحيح للصلاحيات، من خلال مراقبة سلوك الحسابات داخل النظام وتأثير ذلك على مستوى العزل والأمان، وهو ما يوضّح عملياً دور نماذج البنية التحتية كخدمة (IaaS) في دعم تحليل التهديدات الأمنية.

3.1.3 كبيئة اختبار سحابية OpenStack

استُخدمت منصة OpenStack كبيئة اختبار سحابية مُتحمّك بها لدراسة السلوك الأمني ضمن بنية تحتية افتراضية. يتيح هذا الإعداد نشر مكونات النظام ضمن أجهزة افتراضية مستقلة، بما يسمح بتحليل التفاعل بين الحسابات والخدمات في سياق سياسات إدارة الهوية والصلاحيات.

يركّز هذا الاستخدام على مراقبة تأثير الضبط غير الصحيح للصلاحيات وسلوك الحسابات داخل البيئة السحابية، ضمن نطاق معزول لا يؤثر على أنظمة تشغيلية فعلية، الأمر الذي يوفّر أساساً منهجياً مناسباً للتحليل والتقييم الأمني قبل الانتقال إلى بيئات إنتاج حقيقية.

3.2 منصة MicroStack

تُعدّ MicroStack توزيعاً خفيفاً لمنصة OpenStack، طُوّر من قبل شركة Canonical، ويهدف إلى تشغيل بيئة حوسبة سحابية متكاملة على جهاز واحد. يوفّر هذا التوزيع مجموعة من خدمات OpenStack الأساسية ضمن إعداد مبسّط، مما يجعله مناسباً للاستخدام في البيئات التجريبية والتعليمية التي تتطلب موارد محدودة وبنية تشغيلية غير معقّدة.

تم اعتماد MicroStack لتوفير بيئة بنية تحتية كخدمة (IaaS) مصغّرة تُستخدم في نشر وتشغيل مكونات النظام الأمني، مع الحفاظ على الخصائص الأساسية للبيئات السحابية من حيث العزل، وإدارة الموارد، وسهولة التحكم.

3.2.1 المكونات المستخدمة ضمن MicroStack

يتضمّن MicroStack مجموعة من خدمات OpenStack الأساسية التي تلبّي متطلبات البيئة التجريبية، ومن أبرزها:

- Nova: لإدارة وتشغيل الأجهزة الافتراضية.
- Keystone: لإدارة الهوية، والمصادقة، والصلاحيات.
- Neutron: لإدارة الشبكات الافتراضية وآليات الاتصال.

- Glance: لإدارة صور الأنظمة الافتراضية.
 - Horizon: واجهة رسومية تفاعلية تُستخدم لتسهيل عمليات الإدارة والمراقبة.
- تُثبت هذه المكونات وتُهيأ تلقائياً ضمن MicroStack، مما يسهل إعداد البيئة السحابية والبدء بتنفيذ التجارب الأمنية دون الحاجة إلى خطوات نشر معقدة.

3.2.2 الفرق بين OpenStack و Microstack

يوضح الجدول (3-1) الفروقات الجوهرية بين منصة OpenStack وتوزيع MicroStack من حيث الهدف، وبنية النشر، ومتطلبات الموارد، وحالات الاستخدام.

جدول 3.1 مقارنة بين OpenStack و MicroStack

المعيار	OpenStack	Microstack
الهدف	بيئات إنتاجية واسعة النطاق	بيئات اختبار وتطوير صغيرة
عدد العقد	يدعم عدة عقد (Multi-node)	عقدة واحدة فقط (Single-node)
التثبيت والإعداد	إعداد معقد ويتطلب إدارة متقدمة	إعداد مبسط باستخدام واجهة أوامر موحدة
استهلاك الموارد	مرتفع نسبياً	منخفض نسبياً
حالات الاستخدام	الشركات ومراكز البيانات	البيئات التعليمية والتجريبية

تُعدّ OpenStack منصة متكاملة لبناء وإدارة البنى التحتية السحابية واسعة النطاق، في حين يُمثل MicroStack توزيعاً خفيفاً يُستخدم لتشغيل OpenStack ضمن بيئات محدودة الموارد. وبناءً على ذلك، تم اعتماد MicroStack كبيئة تنفيذ عملي تتيح الاستفادة من الخصائص الأساسية لـ OpenStack، مع تجنب التعقيدات التشغيلية المرتبطة بإدارته في البيئات الإنتاجية واسعة النطاق.

3.3 أداة تحليل إدارة الهوية والصلاحيات (IAM Analyzer)

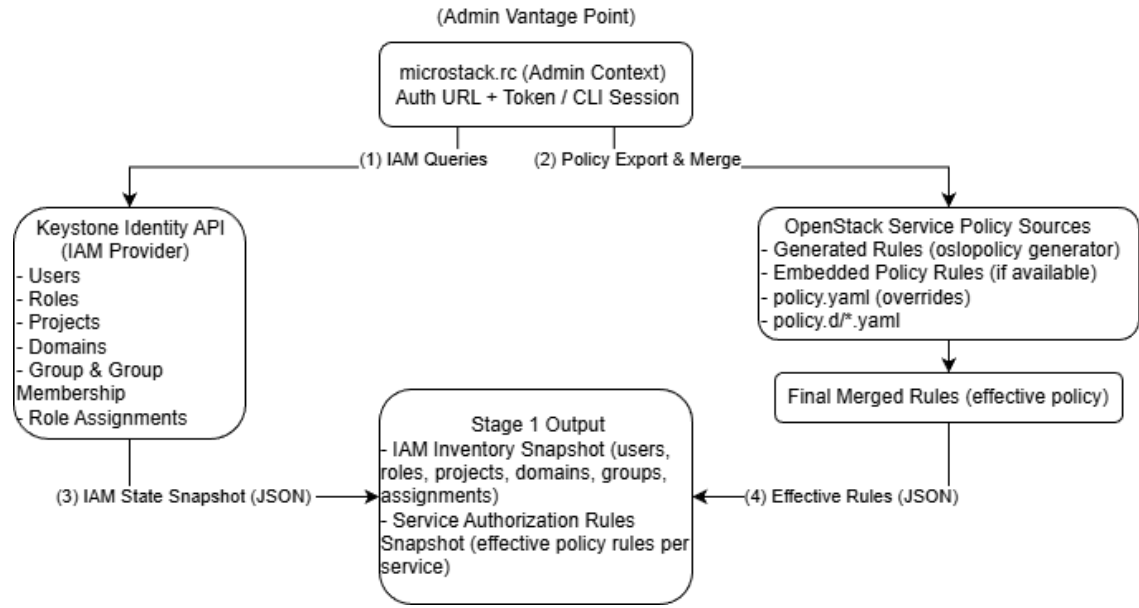
تمثل أداة IAM Analyzer المكوّن التحليلي الأساسي، حيث جرى تصميمها لدراسة بنية إدارة الهوية والصلاحيات داخل البيئة السحابية، بهدف الكشف عن حالات الضبط غير الصحيح للصلاحيات والسلوكيات ذات المخاطر الأمنية. تعتمد الأداة على تسلسلٍ منهجي يتكوّن من أربع مراحل رئيسية مترابطة، تبدأ بجمع البيانات، ثم تهيئتها ومعالجتها مبدئياً، يلي ذلك تمثيلها باستخدام الرسوم البيانية (Graph)، وصولاً إلى تطبيق مجموعة من القواعد الساكنة (Static Rules).

3.3.1 مرحلة التجميع (Collection Phase)

تركّز هذه المرحلة على جمع بيانات إدارة الهوية والصلاحيات من البيئة السحابية، بما يشمل بيانات المستخدمين، الأدوار (Roles)، السياسات (Policies)، والصلاحيات الممنوحة لكل مستخدم ضمن

النظام. تهدف عملية التجميع إلى بناء تمثيل شامل للحالة الفعلية للصلاحيات داخل النظام دون إجراء أي معالجة أو تفسير للبيانات. وتُعد هذه المرحلة الأساس الذي تُبنى عليه جميع المراحل اللاحقة، إذ تعتمد دقة النتائج النهائية بشكل مباشر على اكتمال البيانات المُجمّعة وصحتها.

يوضح الشكل (1-3) المخطط المعماري لمرحلة التجميع، مبيناً مصادر بيانات إدارة الهوية والصلاحيات وسياسات التفويض في البيئة السحابية، وآلية جمعها ضمن سياق إداري موحد، إضافةً إلى المخرجات الناتجة التي تشكّل مدخلاً أساسياً للمراحل التحليلية اللاحقة.

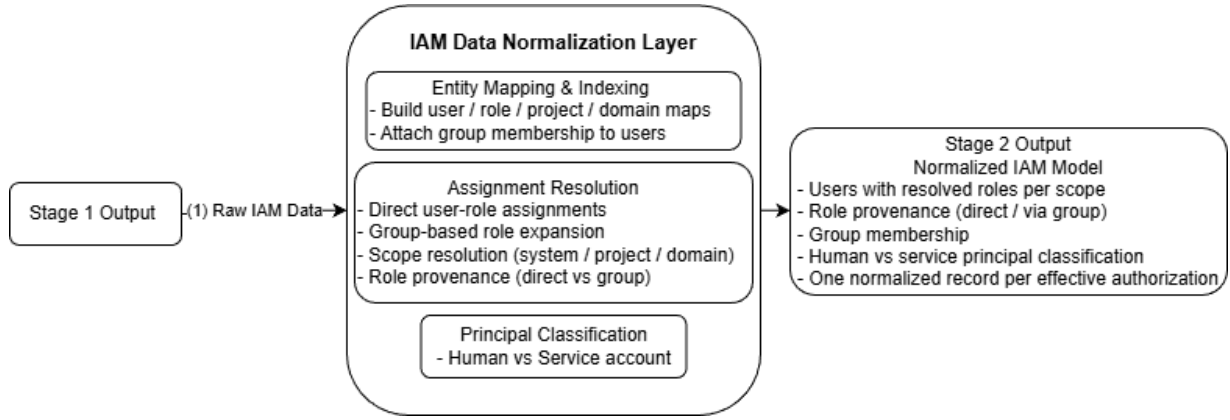


الشكل 1-3 مرحلة التجميع (Collection Phase)

3.3.2 مرحلة التهيئة والمعالجة المبدئية (Normalization Phase)

تهدف هذه المرحلة إلى تنظيم البيانات المُجمّعة وتوحيد صيغ تمثيلها، ويشمل ذلك إزالة التكرار، توحيد بنية العناصر، وربط الكيانات ذات العلاقة ضمن نموذج منطقي متسق. لا تتضمن هذه المرحلة أي استنتاجات أمنية، بل تقتصر على تهيئة البيانات ومعالجتها مبدئياً تمهيداً لاستخدامها في مراحل التحليل اللاحقة.

يوضح الشكل (2-3) المخطط المعماري لمرحلة التهيئة والمعالجة المبدئية، حيث يبين كيفية تحويل بيانات إدارة الهوية والصلاحيات الخام الناتجة عن مرحلة التجميع إلى تمثيل منظم وموحد. يشمل ذلك ربط المستخدمين بالأدوار ونطاقات الصلاحيات المختلفة (System / Project / Domain)، وتوسيع إسنادات المجموعات، بما يهيئ البيانات للاستخدام المباشر في مراحل التحليل اللاحقة.

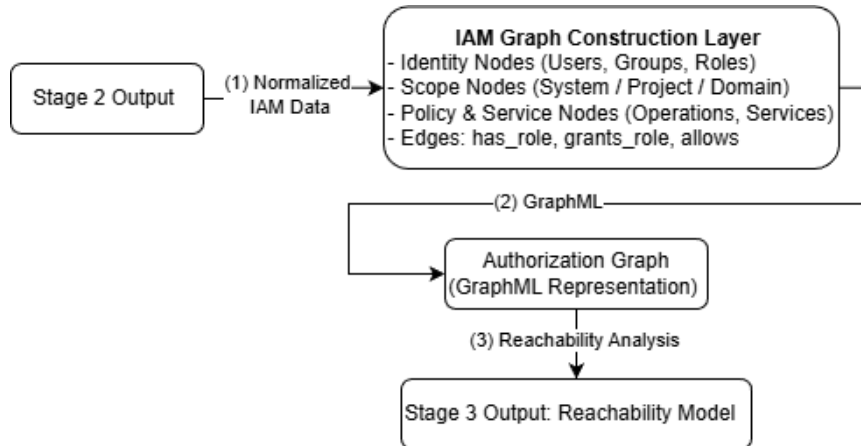


الشكل 2-3 مرحلة التهيئة والمعالجة المبدئية لبيانات IAM

3.3.3 مرحلة بناء الرسم البياني (Graph Construction Phase)

في هذه المرحلة، يتم تمثيل العلاقات بين المستخدمين، الأدوار، ونطاقات الصلاحيات ضمن نموذج قائم على الرسوم البيانية، بما يوفر توصيفاً منهجياً للبنية الداخلية لنظام إدارة الهوية والصلاحيات (IAM). يتيح هذا التمثيل إظهار مسارات الوصول غير المباشرة والعلاقات المركبة التي قد لا تكون واضحة في التمثيلات التقليدية القائمة على القوائم.

يوضح الشكل (3-3) البنية المعمارية لمرحلة بناء الرسم البياني وتحليل الوصول، حيث يتم تحويل نموذج إدارة الهوية والصلاحيات الموحد إلى رسم بياني، ومن ثم إجراء تحليل الوصول (Reachability) لاستخلاص العلاقات الفعلية بين الأدوار والعمليات المسموح بها ضمن النظام. ويستخدم ناتج هذا التحليل لاحقاً كمدخل أساسي لتطبيق القواعد الساكنة وتقييم المخاطر الأمنية.



الشكل 3-3 مرحلة بناء الرسم البياني

3.3.4 مرحلة القواعد الساكنة (Static Rules Phase)

تعتمد هذه المرحلة على تطبيق مجموعة من القواعد الأمنية الساكنة التي تم تحديدها مسبقاً للكشف عن حالات خطرة معروفة. تشمل هذه القواعد حالات الصلاحيات المفرطة، الحسابات غير النشطة التي لا تزال

تمتلك صلاحيات فعالة، أو الأدوار التي تمنح وصولاً أوسع من المطلوب. تُنتج هذه المرحلة مؤشرات واضحة حول مواضع الضعف المحتملة، وتساهم في تحويل نتائج التحليل إلى قرارات أمنية واضحة.

3.3.5 آلية الأتمتة والتنبيه

تعتمد أداة تحليل إدارة الهوية والصلاحيات على تنفيذ مراحل جمع البيانات وتجهيزها وتمثيل العلاقات بصورة منظّمة ضمن تسلسل آلي محدّد. كما تتضمن الأداة آلية تنبيه تستند إلى نتائج القواعد الساكنة، حيث يتم توليد إشعارات عند اكتشاف مؤشرات خطورة أو إعدادات غير آمنة. يساهم ذلك في دعم الكشف المبكر عن الحالات الخطرة ضمن البيئة السحابية.

3.4 المصيدة الأمنية (HoneyPot)

تُعد المصيدة الأمنية أحد المكونات الأساسية في منظومة التحليل الأمني المعتمدة، حيث جرى تصميمها كبيئة معزولة تهدف إلى مراقبة السلوكيات المشبوهة داخل البيئة السحابية دون تعريض الخدمات الفعلية أو البيانات الحساسة لأي مخاطر. تقوم فكرة المصيدة على محاكاة خدمات تبدو حقيقية من منظور المستخدم أو المهاجم، بينما تعمل فعلياً كأداة رصد وتحليل للسلوك غير المصرّح به.

لا يُنظر إلى المصيدة الأمنية في هذا السياق كعنصر مستقل، بل كجزء متكامل من النظام الأمني، بما يتيح الربط بين الصلاحيات الممنوحة نظرياً وسلوك الحسابات عملياً داخل البيئة السحابية.

3.4.1 تصميم بيئة المصيدة الأمنية ضمن MicroStack

تم تصميم بيئة المصيدة الأمنية ضمن بنية MicroStack بحيث تعمل ضمن نطاق مستقل عن باقي مكونات النظام، من خلال فصلها منطقياً على مستوى المشاريع والمجالات. يهدف هذا التصميم إلى تحقيق أعلى درجة من العزل، وضمان عدم انتقال أي نشاط ضار محتمل إلى مكونات أخرى داخل البيئة السحابية.

يسمح هذا الفصل البنيوي بدراسة السلوكيات داخل المصيدة بشكل آمن، مع الحفاظ على سلامة مكونات التحليل وإدارة الهوية والصلاحيات.

3.4.2 دور المصيدة الأمنية في رصد السلوك داخل البيئة السحابية

تُستخدم المصيدة الأمنية كآلية رصد سلوكي ضمن تصميم النظام، بحيث توفر نقطة تفاعل خاضعة للمراقبة داخل البيئة السحابية. يهدف هذا الدور إلى تسجيل الأنشطة التي تنتج عن محاولات الوصول أو التفاعل غير المتوقع مع الخدمات، دون أن تكون هذه الأنشطة موجهة إلى مكونات تشغيلية فعلية.

يسمح هذا التصميم بمراقبة السلوك العملي للحسابات ضمن سياق خاضع للتحكم، وربطه لاحقاً بنتائج تحليل الصلاحيات

3.4.3 تكامل المصيدة الأمنية مع أداة تحليل إدارة الهوية والصلاحيات

يعتمد التكامل بين المصيدة الأمنية وأداة تحليل إدارة الهوية والصلاحيات على ربط نواتج كليهما على مستوى الأحداث الأمنية (Security Events). حيث توفر أداة تحليل الصلاحيات معلومات تتعلق ببنية

الوصول ومستويات الصلاحيات (Privileges)، بينما تسجل المصيدة الأمنية أنشطة سلوكية ناتجة عن تفاعل الحسابات مع خدمات خاضعة للمراقبة.

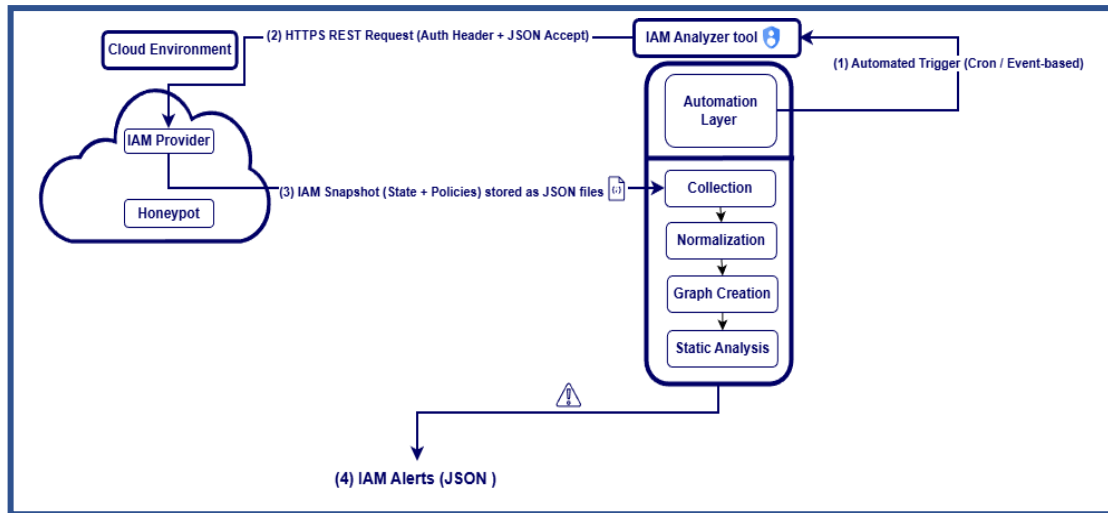
يتم التعامل مع هذه البيانات ضمن سياق موحد يسمح بربط الصلاحيات الممنوحة للحسابات مع سلوكها الفعلي داخل البيئة السحابية، اعتماداً على عناصر مشتركة مثل الهوية (Identity) والزمن (Timestamp). يساهم هذا الربط في التمييز بين الحالات التي تمثل خطورة ناتجة عن إعدادات الصلاحيات فقط، وتلك التي تترافق مع سلوك مشبوه فعلي.

3.5 تكامل مكونات النظام والبنية العامة

يعتمد النظام المقترح على تكامل منظم بين مكونات التحليل البنيوي والسلوكي ضمن بيئة حوسبة سحابية موحدة. يوضح الشكل (3-4) المخطط المعماري العام للنظام المقترح، حيث يبين البنية العامة للنظام، والعلاقات بين مكوناته الرئيسية، وتدقق البيانات والأحداث الأمنية فيما بينها ضمن إطار التحليل الأمني المعتمد.

يتمثل هذا التكامل في ربط أداة تحليل إدارة الهوية والصلاحيات، والمصيدة الأمنية، والبنية السحابية المستضيفة، ضمن تسلسل واضح لتدقيق البيانات. تعمل أداة تحليل إدارة الهوية والصلاحيات على دراسة بنية الوصول والصلاحيات الممنوحة للحسابات داخل البيئة السحابية، في حين تُستخدم المصيدة الأمنية لرصد السلوك الفعلي للحسابات من خلال التفاعل مع خدمات خاضعة للمراقبة.

يتم التعامل مع مخرجات هذين المكونين على مستوى الأحداث الأمنية (Security Events)، بما يسمح بربط نتائج التحليل البنيوي مع المؤشرات السلوكية ضمن سياق واحد. يوفر هذا التكامل رؤية شاملة تجمع بين ما يُسمح للحسابات بالوصول إليه نظرياً (Privileges) وما تقوم به عملياً داخل البيئة السحابية، مما يدعم فهم المخاطر الأمنية بصورة أدق.



الشكل 3-4 المخطط المعماري العام للنظام

تناول هذا الفصل منهجية تصميم وبناء النظام المقترح، موضحاً المكونات التقنية التي يعتمد عليها وآلية تكاملها ضمن بيئة حوسبة سحابية موحدة. تم استعراض دور منصة OpenStack وتوزيع MicroStack في إنشاء البيئة السحابية، وشرح تصميم أداة تحليل إدارة الهوية والصلاحيات والمصيدة الأمنية، إضافةً إلى توضيح آلية التكامل بين التحليل البنيوي للصلاحيات والرصد السلوكي للحسابات وكيفية تفاعل هذه المكونات مع بعضها البعض داخل النظام، وآلية انتقال البيانات فيما بينها ضمن البيئة السحابية، بما يوفّر أساساً منهجياً واضحاً لفهم تصميم النظام وتكامل مكوناته.

الفصل الرابع

التطبيق العملي والنتائج

4 الفصل الرابع - التطبيق العملي والنتائج

يتناول هذا الفصل الجوانب التطبيقية التي تم تنفيذها ضمن إطار المشروع، حيث تم تصميم وتنفيذ منظومة تحليل أمني ضمن بيئة سحابية افتراضية، تهدف إلى دراسة سياسات إدارة الهوية والصلاحيات واكتشاف أخطاء الضبط التي قد تؤدي إلى تصعيد الصلاحيات.

تم اعتماد بيئة MicroStack كنموذج سحابي عملي، وتشغيلها ضمن جهاز افتراضي باستخدام VMware على نظام التشغيل Ubuntu 20.04.6. يركز الفصل على عرض البنية التقنية المعتمدة، وآليات جمع البيانات وتحليلها، مع توضيح التسلسل المنهجي للمعالجة وصولاً إلى استخلاص النتائج الأمنية.

4.1 تطوير أداة تحليل إدارة الهوية والصلاحيات (IAM Analyzer)

تم تطوير أداة تحليل مخصصة تهدف إلى فحص سياسات إدارة الهوية والصلاحيات ضمن البيئة السحابية المعتمدة، اعتماداً على أسلوب التحليل الساكن (Static Analysis) دون التأثير على تشغيل النظام أو سلوكه الفعلي إذ تقوم الأداة بجمع مكونات نظام إدارة الهوية، بما يشمل المستخدمين، الأدوار، المجموعات، وربطها بسياسات الوصول المطبقة على خدمات السحابة المختلفة، ثم توحيد هذه البيانات ضمن تمثيل موحد قابل للتحليل.

تعتمد الأداة على بنية تتيح التعامل المنهجي مع مكونات النظام السحابي، وتوفر أساساً تقنياً واضحاً لاكتشاف حالات الضبط غير الآمن والانحرافات عن مبدأ أقل صلاحية، إضافة إلى دعم تفسير النتائج الأمنية الناتجة عن عملية التحليل.

4.1.1 بنية الأداة وآلية التكامل مع بيئة MicroStack

تم تصميم الأداة وفق بنية طبقية (Modular Architecture) تتيح فصل مكونات التحليل عن بيئة التشغيل السحابية، مع ضمان سهولة التكامل مع خدمات OpenStack المختلفة. يعتمد هذا التصميم على مبدأ الفصل بين منطق جمع البيانات ومنطق التحليل.

تتكامل الأداة بشكل مباشر مع بيئة MicroStack من خلال استخدام واجهات OpenStack البرمجية (APIs) وملفات الإعدادات الفعلية الخاصة بالخدمات السحابية. وقد تم التركيز بشكل خاص على خدمة Keystone المسؤولة عن إدارة الهوية والصلاحيات، باعتبارها العنصر المحوري في التحكم بالوصول داخل المنظومة السحابية، إضافة إلى خدمات أخرى مثل Nova و Neutron و Glance التي تعتمد في آليات التفويض الخاصة بها على سياسات Keystone.

يتم تنفيذ الأداة ضمن نفس بيئة التشغيل الخاصة بـ MicroStack، مما يضمن الوصول إلى السياسات المطبقة فعلياً أثناء تشغيل الخدمات، سواء كانت هذه السياسات معرفّة ضمن ملفات الإعدادات أو مضمّنة ضمن الشيفرة المصدرية للخدمات (policy-in-code). يتيح هذا الأسلوب الحصول على تمثيل دقيق للحالة الأمنية للنظام، بعيداً عن الاعتماد على الإعدادات الافتراضية أو النماذج النظرية. توفّر هذه البنية أساساً تقنياً متيناً لربط مكّونات نظام إدارة الهوية مع سياسات التحكم بالوصول الخاصة بالخدمات السحابية، مما يمكن من تحليل العلاقات بين الكيانات المختلفة داخل النظام واكتشاف حالات الضبط غير الآمن التي قد تؤدي إلى تصعيد الصلاحيات أو انتهاك مبدأ أقل صلاحية.

4.1.2 جمع البيانات من بيئة MicroStack (Collection Phase)

تمثل مرحلة جمع البيانات الأساس الذي تُبنى عليه جميع مراحل التحليل اللاحقة، حيث تهدف إلى استخراج الحالة الفعلية لنظام إدارة الهوية والصلاحيات كما هي مطبقة أثناء تشغيل البيئة السحابية، دون الاعتماد على افتراضات نظرية أو إعدادات افتراضية. في هذا المشروع، تم تنفيذ عملية الجمع بالاعتماد على واجهات OpenStack البرمجية الرسمية (OpenStack APIs)، مع التركيز الأساسي على خدمة Keystone باعتبارها المزود المركزي لإدارة الهوية والتحكم بالوصول داخل منظومة OpenStack. تعتمد عملية الجمع على إنشاء اتصال مصادق (Authenticated Session) مع Keystone باستخدام بيانات الاعتماد الخاصة بالبيئة السحابية، والتي يتم تحميلها مباشرة من متغيرات البيئة الخاصة بـ MicroStack. يضمن هذا الأسلوب أن البيانات المستخرجة تمثل الحالة التشغيلية الفعلية للنظام، دون إحداث أي تغيير في إعدادات الخدمات أو التأثير على استقرارها، وهو ما يتوافق مع مبدأ التحليل الساكن (Static Analysis).

تشمل البيانات المستخرجة من Keystone مجموعة شاملة من مكّونات نظام إدارة الهوية، وتتضمن معلومات المستخدمين (Users)، المشاريع (Projects)، الأدوار (Roles)، والمجموعات (Groups)، إضافة إلى علاقات الإسناد (Role Assignments) التي تحدد كيفية منح الأدوار للمستخدمين أو المجموعات ضمن نطاقات مختلفة. يتم جمع إسنادات الأدوار بجميع أشكالها المدعومة في Keystone، بما في ذلك الإسناد على مستوى النظام (System Scope)، المشاريع (Project Scope)، والمجالات (Domain Scope)، مما يوفر صورة دقيقة عن نموذج التفويض المعتمد في البيئة.

إلى جانب ذلك، يتم استخراج بيانات عضوية المجموعات (Group Memberships) بشكل صريح، حيث يتم ربط كل مجموعة بالمستخدمين الأعضاء فيها. تعتبر هذه البيانات عنصرًا محوريًا في تحليل الصلاحيات، نظرًا لأن الكثير من الصلاحيات في البيئات السحابية تُمنح بشكل غير مباشر عبر المجموعات، وليس عبر إسناد مباشر للمستخدمين.

ولتعزيز سياق البيانات المجمعة وإتاحة إمكانية تتبعها لاحقًا، يتم إرفاق معلومات وصفية (Metadata) بعملية الجمع، مثل وقت التنفيذ، عنوان خدمة المصادقة (Auth URL)، اسم المشروع، واسم المستخدم الذي تم استخدامه لإجراء عملية الجمع. يساهم ذلك في ربط النتائج بسياقها الزمني والبيئي، ويتيح مقارنة لقطات مختلفة (Snapshots) للنظام عند الحاجة.

بالإضافة إلى بيانات إدارة الهوية، تشمل مرحلة الجمع استخراج معلومات الخدمات المسجلة في Keystone (Service Catalog) ونقاط الوصول (Endpoints) الخاصة بها. لا تُستخدم هذه البيانات مباشرة في منح الصلاحيات، لكنها تلعب دورًا مهمًا لاحقًا في تمييز حسابات الخدمات عن المستخدمين البشريين، وفي ربط الصلاحيات بسياقها الوظيفي داخل المنظومة السحابية.

وبالتوازي مع جمع بيانات الهوية، يتم جمع سياسات التحكم بالوصول (Access Control Policies) الخاصة بخدمات OpenStack المختلفة مثل Nova و Neutron و Glance وغيرها. تعتمد عملية جمع السياسات على آليتين متكاملتين:

الأولى استخراج السياسات المضمنة للخدمات (Policy-in-Code) باستخدام أدوات OpenStack الرسمية، والثانية قراءة ملفات السياسات الفعلية المعرفة ضمن ملفات الإعدادات (/ policy.yaml / policy.json / policy.d) في بيئة MicroStack. يضمن هذا الدمج الحصول على السياسة الفعالة (Effective Policy) التي تعتمد عليها الخدمات أثناء التشغيل، وليس فقط القيم الافتراضية.

ناتج مرحلة الجمع هو مجموعة بيانات خام (Raw Snapshot) تمثل الحالة الفعلية لنظام إدارة الهوية وسياسات التحكم بالوصول في البيئة السحابية في لحظة زمنية محددة. يتم حفظ هذه البيانات بصيغة JSON وتمثيلها كما هي إلى مرحلة التطبيق والمعالجة اللاحقة دون إجراء أي تعديل عليها، بما يحافظ على سلامة البيانات الأصلية ويضمن فصلًا واضحًا بين منطق الجمع ومنطق التحليل.

4.1.3 معالجة وتوحيد البيانات (Normalization and Preprocessing)

بعد الانتهاء من مرحلة جمع البيانات (Collection) من خدمة Keystone وخدمات OpenStack المرتبطة، يتم تمرير المخرجات الخام بصيغة JSON إلى مرحلة التطبيع (Normalization) بهدف تحويلها من شكلها الأصلي غير المتجانس إلى تمثيل موحد (Unified Representation) قابل للتحليل اللاحق وبناء الرسم البياني (Graph Construction). تركز هذه المرحلة على إعادة تنظيم بيانات الهوية والصلاحيات بحيث تصبح العلاقات بين المستخدمين والأدوار والنطاقات (Scopes) واضحة ومهيكلية، مع الحفاظ على مصدر منح الصلاحية (Provenance) لضمان إمكانية تفسير النتائج لاحقاً عند توليد التنبيهات.

تبدأ عملية التطبيع ببناء خرائط مرجعية (Base Maps) تعتمد على معرفات الكيانات (IDs) كمفاتيح أساسية، وتشمل خرائط المستخدمين (Users)، المشاريع (Projects)، الأدوار (Roles)، المجموعات (Groups)، إضافة إلى النطاقات/المجالات (Domains) عند توفرها. يتم في هذه الخطوة توحيد الحقول الأساسية لكل كيان (مثل: id، name، domain_id) والتأكد من تجاهل السجلات غير المكتملة أو التي تفتقد معرفاً صالحاً، مما يرفع من موثوقية البيانات قبل بدء التحليل.

بعد ذلك، يتم ربط المستخدمين بعضويتهم في المجموعات عبر بيانات group_membership المستخرجة من Keystone. تُحوّل هذه البيانات إلى بنية مباشرة على مستوى المستخدم (users[uid]["groups"]) لتسهيل الاستعلام لاحقاً حول عضوية المستخدم وما إذا كانت الصلاحيات مُنحت بشكل مباشر أو عبر مجموعة. تعتبر هذه الخطوة أساسية لأنها تمثل أحد المسارات الشائعة لمنح الصلاحيات في بيئات IAM، كما أنها تؤثر على تفسير حالات التصعيد أو الاتساع غير المبرر للصلاحيات.

الخطوة الأكثر أهمية في التطبيع تتمثل في معالجة إسنادات الأدوار (Role Assignments) وتحويلها إلى تمثيل موحد حسب نطاق الصلاحية (Scope). تعتمد Keystone ثلاثة نطاقات رئيسية لمنح الدور:

- System Scope (صلاحيات على مستوى النظام)

- Project Scope (صلاحيات ضمن مشروع محدد)

- Domain Scope (صلاحيات ضمن نطاق/مجال)

تقوم الأداة بتحليل كل role assignment وتحديد نوع النطاق بشكل صريح، ثم إسقاطه داخل بنية المستخدم إلى أحد الأقسام التالية:

- user["system"] للأدوار على مستوى النظام.

- user["projects"][project_id] للأدوار ضمن المشاريع.

- user["domains"][domain_id] للأدوار ضمن المجالات.

ولضمان الدقة وقابلية التفسير، لا يتم تخزين اسم الدور فقط، بل يتم تخزين الدور مع مصدر منحه (via) على مستوى الدور نفسه (Per-Role Provenance)، بحيث يصبح لكل دور سجل مستقل يوضح ما إذا كان الدور قد مُنح للمستخدم بشكل مباشر (type: direct) أو عبر مجموعة (type: group) مع (group_id). هذا القرار التصميمي يمنع الالتباس الذي قد يحدث عند تخزين مصدر المنح بشكل منفصل عن الدور، كما أنه يوفر دليلاً صريحاً عند توليد تنبيه أمني يوضح مسار منح الصلاحية. عملياً، يتم تنفيذ ذلك عبر تمرير معلومات المنح إلى دالة مساعدة تقوم بإضافة الدور إلى نطاق المستخدم المناسب مع حفظ الـ provenance.

ولأن Keystone تسمح بإسناد الأدوار للمجموعات أيضاً، يتم التعامل مع هذا النوع من الإسناد على مرحلتين:

- التمرير الأول (PASS 1): يتم تسجيل إسنادات الأدوار للمجموعات ضمن مخزن مؤقت (buffer) دون توسيعها فوراً.

- التمرير الثاني (PASS 2): يتم توسيع هذه الإسنادات عبر عضوية المجموعة (group_membership) وإسناد الدور لكل مستخدم عضو في المجموعة، مع توثيق أن مصدر المنح هو مجموعة وليس إسناداً مباشراً.

يسمح هذا الأسلوب بفصل منطق اكتشاف الإسنادات عن منطق توسيعها، ويجعل مرحلة التطبيع أكثر وضوحاً وأسهل للتحقق والاختبار.

بعد إتمام ربط الأدوار، يتم تنفيذ عمليات تنظيف (Cleaning) تشمل إزالة التكرار وترتيب القوائم لضمان اتساق المخرجات. تتم إزالة التكرارات وفق مفتاح مركب يجمع بين (اسم الدور + نوع المصدر + معرف المجموعة عند وجوده)، مما يمنع تضخيم البيانات دون فقدان معلومات الدليل. كما يتم ترتيب القوائم لتصحيح المخرجات قابلة للمقارنة بين لقطات مختلفة (Snapshots) وتسهيل عمليات الاختبار والتحقق.

أخيراً، تُطبّق خطوة تصنيف المستخدمين إلى مستخدمين بشريين (Human Users) مقابل حسابات خدمات (Service Principals) باستخدام قواعد استدلالية (Heuristic Rules) غير معتمدة على تعلم آلي. تعتمد هذه القواعد على مطابقة أسماء المستخدمين مع أسماء الخدمات المعروفة في OpenStack (مثل nova, neutron, cinder, glance, placement) ومع أسماء الخدمات المستخرجة فعلياً من Keystone (services catalog)، إضافة إلى أنماط تسمية شائعة لحسابات الخدمة. ينتج عن ذلك الحقل is_human لكل مستخدم، والذي يُستخدم لاحقاً في بناء رسوم بيانية موجهة لتحليل مسارات التصعيد الخاصة بالمستخدمين البشريين أو لتصفية الضوضاء الناتجة عن حسابات الخدمات.

ناتج مرحلة التطبيع هو ملف normalized.json الذي يمثل صورة موحّدة ودقيقة عن علاقات الهوية والصلاحيات في البيئة، مع الحفاظ على مصدر منح الصلاحيات على مستوى كل دور، مما يوفر أساساً قوياً لبناء الرسم البياني وتحليل حالات الضبط غير الآمن وفق قواعد التحليل الساكن في المراحل اللاحقة.

4.1.4 بناء الرسم البياني وتحليل الوصول (Graph Construction & Reachability)

في هذه المرحلة تم تحويل بيانات إدارة الهوية والصلاحيات، بعد معالجتها وتطبيعها في المرحلة السابقة، إلى نموذج رسم بياني موجه (Directed Graph) يعبر بشكل صريح وقابل للتحليل عن العلاقات البنوية بين الكيانات المختلفة داخل نظام OpenStack. يهدف هذا النموذج إلى تمكين التحليل البنوي للصلاحيات، ودعم عمليات تتبع التفويض، واكتشاف مسارات الوصول المحتملة التي قد تؤدي إلى أخطاء ضبط أو تصعيد صلاحيات.

يعتمد النموذج على تمثيل الكيانات الأساسية كنقاط (Nodes)، والعلاقات الدلالية بينها كحواف (Edges)، مع الحفاظ الصارم على مفهوم النطاق (Scope) الذي يشكل عنصراً محورياً في آلية التفويض داخل Keystone. وتشمل الكيانات الممثلة في الرسم البياني: المستخدمين، المجموعات، الأدوار، النطاقات

(System / Domain / Project)، الخدمات، نقاط النهاية (Endpoints)، وعمليات التحكم بالوصول (Policy Operations).

4.1.4.1 تمثيل الهوية والتفويض (Identity & Authorization Layer)

يبدأ بناء الرسم البياني من طبقة الهوية، حيث يتم تمثيل كل مستخدم وكل مجموعة كنقطة مستقلة، مع إنشاء علاقات العضوية بينهما. يتم بعد ذلك تمثيل الأدوار كنقاط منفصلة مرتبطة صراحة بنطاقها، بحيث لا يُنظر إلى الدور كصلاحية مطلقة، بل كصلاحية صالحة فقط ضمن نطاق محدد. يتم ربط المستخدمين بالأدوار من خلال حواف تعبّر عن امتلاك الدور، كما يتم ربط الأدوار بالنطاقات التي تُمنح ضمنها.

ويتم الاحتفاظ بمعلومة مصدر الدور (Provenance)، أي ما إذا كان الدور قد مُنح مباشرةً للمستخدم أو تم توريثه عبر مجموعة. يُترجم هذا المفهوم في الرسم البياني بعلاقات مخصصة من نوع grants_role بين المجموعات والأدوار، ما يسمح لاحقاً بتحديد مسارات التفويض غير المباشر وتحليل مخاطر التوسع غير المقصود للصلاحيات.

4.1.4.2 تمثيل سياسات التحكم بالوصول (Policy Layer)

في طبقة السياسات، يتم تمثيل كل قاعدة تحكم بالوصول (Policy Rule) كعملية مستقلة مرتبطة بالخدمة التي تنتمي إليها. تعتمد عملية الربط بين الأدوار والعمليات على تحليل شروط السياسة بعد توسيع المراجع غير المباشرة من نوع <rule:<alias>، بما يضمن الكشف الكامل عن الأدوار المشار إليها فعلياً داخل منطق السياسة.

لا يتم في هذه المرحلة اتخاذ أي قرار أمني أو تصنيفي، بل يُحافظ على تمثيل محايد يربط:

- الأدوار بالعمليات التي تسمح بها السياسات،

- والعمليات بالخدمات التي تنفذها.

كما يتم رسم العمليات بعلامات محايدة مستخرجة من شروط السياسات، مثل قيود النطاق أو متطلبات is_admin، بهدف تسهيل التصفية والتحليل البنيوي في المراحل اللاحقة دون فرض أي تفسير دلالي مسبق.

ويُستخدم هذا التمثيل لاحقاً كأساس لتحليل الوصول (Reachability) دون الحاجة إلى إعادة تفسير منطق السياسات أو تنفيذها تشغيلياً.

4.1.4.3 تمثيل البنية التحتية (Infrastructure Layer)

لدعم تحليل أخطاء الضبط المرتبطة بكتالوج الخدمات، تم تضمين طبقة البنية التحتية ضمن الرسم البياني الشامل، حيث يتم تمثيل نقاط النهاية (Endpoints) وربطها بالخدمات المرتبطة بها. يتيح هذا الربط دراسة التوافق بين سياسات التفويض المعرّفة نظرياً والبنية الفعلية المعروضة عبر واجهات OpenStack، دون التأثير على حالة النظام أو سلوكه التشغيلي.

يسمح هذا التمثيل بالكشف البنيوي عن حالات عدم الاتساق من نوع:

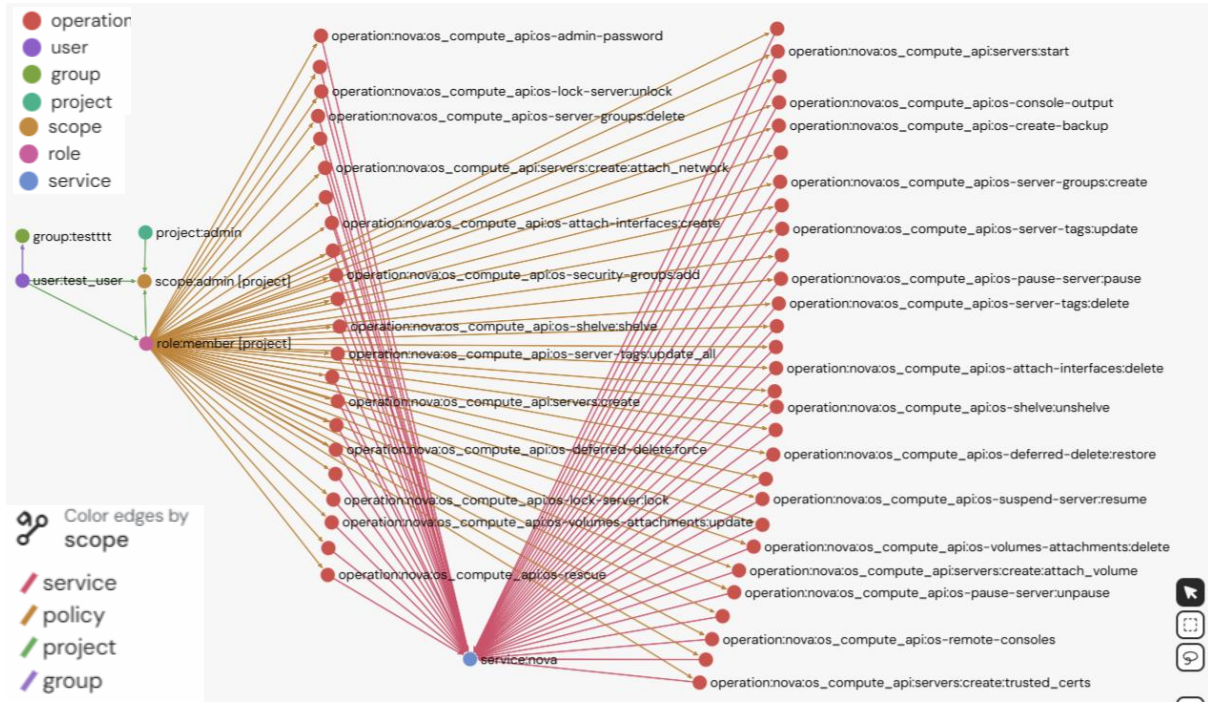
- سياسة تسمح بعملية لا يقابلها Endpoint فعلي.
- Endpoint مكشوف دون وجود سياسة واضحة تنظمه.
- أو اختلاف بين نطاق السياسة (Policy Scope) ومستوى تعريض الخدمة (Endpoint Exposure).

4.1.4.4 خصائص النموذج

يتميز النموذج الناتج بالخصائص التالية:

- فصل واضح بين الهوية، التفويض، السياسات، والبنية التحتية.
 - الحفاظ على مفهوم النطاق في جميع علاقات الصلاحيات.
 - تمثيل مصدر الصلاحية (مباشر أو عبر مجموعة) بشكل قابل للتتبع.
 - حيادية النموذج، حيث لا يتم إطلاق تنبيهات في هذه المرحلة.
- تم تصدير الرسم البياني بصيغة GraphML، ما يسمح باستكشافه وتحليله بصرياً باستخدام أدوات تحليل الرسوم البيانية مثل Gephi، إضافة إلى إمكانية تطبيق خوارزميات تحليل المسارات، المركزية، واكتشاف الأنماط البنيوية في المراحل اللاحقة من البحث.

يوضّح الشكل (4-1) مثلاً تمثيلاً للرسم البياني الناتج عن هذه المرحلة، حيث تُعرض العلاقات بين كيانات الهوية، النطاقات، الأدوار، عمليات التحكم بالوصول، والخدمات المرتبطة بها، باستخدام أداة Gephi، وذلك بهدف إظهار البنية الداخلية للنموذج الرسومي والعلاقات المكوّنة له.



الشكل 1-4 الرسم البياني للعلاقات

بعد تصدير الرسم البياني بصيغة GraphML، تم تنفيذ تحليل الوصول (Reachability) لاستخلاص العلاقات الفعلية بين الأدوار والعمليات (Role → Operation). يهدف هذا التحليل إلى تحويل السياسات المعرفة على مستوى الخدمات إلى نموذج قابل للقياس يوضح ما الذي يمكن لكل دور تنفيذه فعلياً ضمن نطاقاته المختلفة. يمثل ناتج هذه المرحلة ملفاً منظماً (Reachability Model) يربط كل دور بمجموعة العمليات التي يستطيع الوصول إليها، ويُستخدم هذا النموذج لاحقاً كأساس لتطبيق القواعد الساكنة واكتشاف الصلاحيات المفرطة ومسارات التفويض ذات المخاطر المحتملة.

4.1.5 مرحلة القواعد الساكنة (Static Rules Phase)

تمثل مرحلة القواعد الساكنة المرحلة التحليلية الأهم ضمن مسار العمل المعتمد، إذ تشكل نقطة الانتقال من التمثيل البنوي لنظام إدارة الهوية والصلاحيات إلى استخلاص مؤشرات أمنية قابلة للتفسير. تعتمد هذه المرحلة على تطبيق مجموعة محدودة ومدرسة من القواعد الساكنة (Static Rules) على نموذج الرسم البياني وناتج تحليل الوصول (Reachability)، بهدف الكشف عن أنماط ضبط غير آمن للصلاحيات دون الاعتماد على بيانات تشغيلية أو سلوكية.

تستند هذه المرحلة إلى مبدأ أساسي أن العديد من مخاطر تصعيد الصلاحيات في البيئات السحابية يمكن اكتشافها من خلال تحليل بنية التفويض نفسها، حتى في غياب أي نشاط هجومي فعلي، وهو ما يجعلها مناسبة للتحليل الاستباقي ضمن بيئات البنية التحتية كخدمة (IaaS).

4.1.5.1 مدخلات مرحلة القواعد الساكنة

تعتمد مرحلة القواعد الساكنة على مخرجات المراحل السابقة دون إجراء أي عمليات جمع إضافية للبيانات. وتشمل المدخلات الأساسية ما يلي:

- نموذج الرسم البياني الموجه (GraphML) الذي يمثل العلاقات البنيوية بين المستخدمين، الأدوار، النطاقات، السياسات، والخدمات.
- ناتج تحليل الوصول (Reachability Model) الذي يربط كل دور بمجموعة العمليات التي يمكنه تنفيذها فعلياً.
- معلومات مصدر منح الصلاحيات (Provenance) التي توضح ما إذا كانت الصلاحية مُنحت مباشرة أو عبر مجموعة.
- خصائص النطاق (System / Project / Domain) المرتبطة بكل دور.

4.1.5.2 منهجية تصميم القواعد الساكنة

تم تصميم القواعد الساكنة وفق منهجية انتقائية صارمة، تأخذ بعين الاعتبار قابلية التحقق الساكن (Static Verifiability) والملاءمة المعمارية لبيئة MicroStack. لا تهدف هذه القواعد إلى تغطية جميع الضوابط الواردة في أطر العمل القياسية مثل NIST و CIS، بل تركز على الضوابط التي يمكن تمثيلها واكتشافها بشكل مباشر من خلال بنية IAM ونموذج التفويض.

تعتمد كل قاعدة على نمط بنيوي (Structural Pattern) محدد داخل الرسم البياني، مثل:

- دور يمتلك عدداً غير مبرر من العمليات الحساسة.
 - أدوار ذات نطاق نظامي (System Scope) ممنوحة لمستخدمين بشريين.
 - صلاحيات عالية تم توريثها عبر مجموعات دون تخصيص صريح.
 - مسارات وصول غير مباشرة تؤدي إلى عمليات إدارية حرجية.
- يضمن هذا الأسلوب أن تكون نتائج التحليل قابلة للتفسير، وقائمة على أدلة بنيوية واضحة، دون اللجوء إلى تقديرات احتمالية أو افتراضات سلوكية.

4.1.5.3 العلاقة مع المعايير القياسية (NIST / CIS)

تم تصميم القواعد الساكنة المعتمدة في هذا المشروع بالاستناد إلى ضوابط مختارة من أطر العمل القياسية المعترف بها، وعلى رأسها معيار NIST SP 800-53 (الإصدار الخامس) و CIS Benchmarks، وبخاصة الضوابط المرتبطة بالتحكم بالوصول ومبدأ أقل صلاحية (Least Privilege).

ولا يهدف هذا الربط إلى تطبيق هذه المعايير بشكل حرفي أو شامل، بل إلى اشتقاق قواعد قابلة للتحقق ضمن نطاق التحليل الساكن وضمن السياق المعماري لبيئة البنية التحتية كخدمة (IaaS) المعتمدة في MicroStack.

يوضّح الجدول (1-4) القواعد الساكنة المطبّقة مع الضوابط القياسية من أطر NIST SP 800-53 و CIS Benchmarks، بالإضافة إلى مصدر كل قاعدة، ونطاق قابليتها للتطبيق ضمن بيئة البنية التحتية كخدمة (IaaS)، والأساس المنهجي الذي اعتمد في اختيارها.

جدول 1-4 القواعد الساكنة المطبّقة

الضابط القياسي	مصدر الاشتقاق القياسي	مثال على القاعدة	فئة القاعدة (Taxonomy)
AC-6 (Least Privilege)	NIST SP 800-53r5	Human user has admin at system scope	T1 – Excessive Privilege
AC-5, AC-6	NIST SP 800-53r5	Privileged role granted via group	T2 – Privileged Role Exposure
enforce_scope	OpenStack Oslo Policy	Project role reaches system-only operation	T3 – Scope Violation
enforce_new_defaults	OpenStack Oslo Policy	Operation uses is_admin semantic	T4 – Policy Semantic Weakness
AC-2, AC-6	NIST SP 800-53r5	Non-admin reaches identity:create_user	T5 – Dangerous Operation Reachability
AC-2, AC-6	NIST SP 800-53r5	Service principal has admin role	T6 – Service Principal Hygiene
CIS 2.15	CIS Benchmarks (Conceptual)	Policy contains wildcard token	T8 – Over-broad Policy
Identity	OpenStack Security Guide	Non-system role reaches system admin ops	T9 – Admin Surface Exposure
enforce_scope	Oslo Policy	Project admin reaches system operation	T10 – Cross-scope Exposure

اقتصرت تطبيق ضوابط NIST و CIS في هذا المشروع على القواعد التي يمكن التحقق منها اعتماداً على الحالة الساكنة لإدارة الهوية والصلاحيات، دون الحاجة إلى بيانات تشغيلية مثل سجلات الدخول، تسلسل الأحداث الزمنية، أو تكامل مع أنظمة إدارة الأحداث الأمنية (SIEM).

ويرجع ذلك إلى أن عدداً كبيراً من الضوابط الواردة في هذه الأطر يتطلب مراقبة سلوكية مستمرة أو تحليلاً زمنياً للأحداث، وهو ما يندرج عادة ضمن بيانات البرمجيات كخدمة (SaaS)، ولا يتوفّر افتراضياً ضمن بيانات IaaS مثل MicroStack.

وبناءً عليه، تم استبعاد الضوابط التي لا يمكن دعم نتائجها بأدلة مباشرة مستخرجة من نموذج التفويض نفسه، وتفادياً لإنتاج استنتاجات أمنية لا يمكن التحقق منها ضمن نطاق البيانات المتاحة.

يعكس هذا النهج الانتقائي التزام المشروع بتطبيق المعايير القياسية وفق قابليتها التقنية للتحقق، وليس وفق شموليتها النظرية. وبذلك، لا تُعدّ قلة عدد القواعد الساكنة المطبّقة مؤشراً على محدودية التحليل، بل نتيجة

مباشرة لاختيار نطاق تحليلي واضح، قائم على التحليل البنيوي لإدارة الهوية والصلاحيات ضمن بيئة laaS، مع الحفاظ على دقة النتائج وقابليتها للتفسير.

4.1.5.4 ناتج مرحلة القواعد الساكنة

ناتج هذه المرحلة هو مجموعة من المؤشرات الأمنية (Security Indicators) التي تشير إلى مواضع ضعف محتملة في ضبط الصلاحيات، دون تصنيفها كحوادث أمنية مؤكدة. يتم التعبير عن هذه المؤشرات على شكل نتائج تحليلية توضح:

- الكيان المتأثر (User / Role / Group).
- نوع النمط المكتشف.
- المسار البنيوي الذي أدى إلى النتيجة (Path Explanation).
- القاعدة الساكنة التي تم تفعيلها.

يسمح هذا النهج بتقديم نتائج قابلة للتفسير والمراجعة، ويمكن استخدامها لاحقاً كأساس لقرارات أمنية أو لمراحل تكامل مستقبلية مع أنظمة رصد وتشغيل أكثر تقدماً.

4.1.5.5 أهمية المرحلة ضمن السياق العام للنظام

تُعد مرحلة القواعد الساكنة نقطة التحول الأساسية في النظام المقترح، إذ تنتقل فيها عملية التحليل من مستوى التمثيل البنيوي إلى مستوى الاستدلال الأمني الموجه. ومن خلال هذه المرحلة، يصبح بالإمكان ربط بنية التفويض النظرية بمخاطر أمنية محتملة، دون الحاجة إلى تنفيذ أي نشاط هجومي أو انتظار وقوع حادث فعلي.

وبذلك، تمثل هذه المرحلة الأساس الذي يُبنى عليه أي توسع مستقبلي للنظام، سواء من خلال إضافة قواعد أكثر تقدماً، أو دمج التحليل الساكن مع آليات رصد سلوكي عند توفر البنية الداعمة لذلك.

4.2 إنشاء المصيدة الأمنية (HoneyPot Deployment)

تم إنشاء المصيدة الأمنية ضمن بيئة MicroStack بهدف إدخال مكّون سلوكي تجريبي داخل البنية السحابية، يعمل كنقطة تفاعل خاضعة للضبط والمراقبة، دون التأثير على مكونات التحليل البنيوي لإدارة الهوية والصلاحيات. لا تهدف المصيدة في هذا السياق إلى صد الهجمات أو منعها، بل إلى توفير بيئة تبدو قابلة للوصول وتفاعل المستخدمين معها، بما يسمح بدراسة سلوكيات الوصول ضمن نطاق مسيطر عليه.

اعتمدت عملية الإنشاء على نشر خادم افتراضي مخصص للمصيدة ضمن مشروع مستقل داخل MicroStack، وربطه ببنية شبكية معزولة، مع تطبيق سياسة وصول مقصودة عبر مجموعات الأمن (Security Groups). يضمن هذا التصميم الفصل المنهجي بين بيئة المصيدة وبقية مكونات النظام، مع الحفاظ على إمكانية تعريض خدمات المصيدة بشكل مقصود ومدرّوس.

4.2.1 نشر خادم افتراضي مخصص للمصيدة

تم نشر خادم افتراضي (Instance) باسم honeypot-vm يمثل المصيدة الأمنية، باستخدام صورة نظام تشغيل خفيفة من نوع ubuntu-cloud، وذلك لملاءمتها لبيئات الاختبار وسهولة إدارتها. جرى اختيار مواصفات موارد متوازنة (المعالج، الذاكرة، والتخزين) تتناسب مع طبيعة المصيدة، بحيث تكون كافية لاستقبال الاتصالات وتنفيذ الخدمات الوهمية دون استهلاك مفرط لموارد البيئة السحابية.

4.2.2 إنشاء شبكة منطقية معزولة للمصيدة وربطها بالموجّه

لتحقيق العزل الشبكي، تم إنشاء شبكة افتراضية مخصصة للمصيدة (Trap Network) داخل MicroStack، وربطها بموجّه افتراضي (Router) مستقل يتيح التحكم بحركة المرور بين شبكة المصيدة وبقية الشبكات أو الشبكة الخارجية وفق الحاجة. يوفّر هذا التصميم فصلاً منطقياً واضحاً يسمح بإجراء تجارب تعريض خدمات المصيدة ضمن نطاق محدد، مع منع أي انتشار جانبي محتمل نحو مكونات أخرى في البيئة السحابية.

4.2.3 ضبط سياسة الوصول باستخدام مجموعات الأمن (Security Groups)

تم تعريف مجموعة أمن مخصصة وربطها مباشرة بالخادم الافتراضي الخاص بالمصيدة، بدلاً من استخدام مجموعة الأمن الافتراضية. يتيح هذا الإجراء التحكم الدقيق في كيفية تعريض المصيدة للشبكة، ويمكن تطبيق سياسات عامة قد لا تتوافق مع طبيعة المصيدة.

تم ضبط قواعد الوصول كما يلي:

- قواعد Ingress (الوارد): تم السماح بالوصول إلى جميع المنافذ والخدمات الواردة (Open Ingress)، بحيث تبدو المصيدة كخدمة متاحة بالكامل من منظور أي مستخدم أو جهة خارجية. يهدف هذا الإعداد إلى زيادة سطح التعريض (Attack Surface) بشكل مقصود، وهو عنصر أساسي في تصميم المصائد الأمنية، حيث يُفترض أن تبدو الخدمة غير مقيّدة لجذب محاولات الوصول أو التفاعل.

- قواعد Egress (الصادر): تم ضبط حركة المرور الصادرة بما يوازن بين المتطلبات التشغيلية الأساسية للخادم (مثل التحديثات أو الاتصالات الداخلية الضرورية) وبين تقليل المخاطر، بحيث لا تتحول المصيدة إلى نقطة انطلاق لأي نشاط خارج النطاق التجريبي أو إلى أداة غير مقصودة لإعادة توجيه الهجمات.

يعكس هذا الإعداد مبدأ التعريض المقصود تحت السيطرة (Controlled Exposure)، حيث يتم السماح بأوسع نطاق وصول ممكن لخدمة المصيدة ضمن حدود معروفة ومسيطر عليها، مع الاحتفاظ بالقدرة على تقييد أو إيقاف الوصول عند الحاجة.

4.2.4 تهئية مبدأ جمع الأدلة (Evidence) من السجلات

ضمن إطار تصميم المصيدة، تم اعتماد مبدأ توثيق الأحداث بالاستناد إلى السجلات النظامية (Logs) المتاحة داخل بيئة MicroStack، دون الاعتماد على أنظمة مراقبة مركزية أو تكامل مع منصات SIEM. تم التركيز بشكل خاص على سجلات خدمات إدارة الهوية والتحكم بالوصول، مثل خدمة Keystone، باعتبارها نقطة مركزية في تسجيل التحذيرات والتنبيهات المرتبطة بالسياسات وسلوك الوصول. وحفظها في ملفات مخرجات منفصلة. يحقق هذا الأسلوب فائدتين:

- توثيق قابل للمراجعة حول الحالة التشغيلية للخدمات والتنبيهات المرتبطة بالسياسات أو الإعدادات.

- توفير الأثر الرقمي المتسلسل للأحداث (Digital Audit Trail)، والذي يمكن ربطه لاحقاً بمنظومات تحليل أو مراقبة أكثر تقدماً عند توسيع النظام، بما يوفر دليلاً رقمياً قابلاً للمراجعة.

بنهاية هذه المرحلة أصبحت المصيدة ممثلة بخادم افتراضي ضمن شبكة مخصصة ومعزولة، مع سياسة وصول مضبوطة عبر Security Groups، وآلية مبدئية لجمع الأدلة من السجلات. يتضمن هذا الإعداد جاهزية المصيدة كعنصر تجريبي داخل النظام المقترح، بحيث يمكن استخدامها لاحقاً للرصد السلوكي أو للتكامل مع طبقات تحليل وتشغيل إضافية عند توفر البنية الداعمة.

4.3 نتائج التحليل التجريبي (Experimental Results)

للتحقق من فعالية النظام المقترح وقدرته على اكتشاف أنماط ضبط غير آمن للصلاحيات، تم تنفيذ سيناريو تجريبي مضبوط ضمن بيئة MicroStack، يهدف إلى تقييم قدرة النظام المقترح على اكتشاف أنماط ضبط غير آمن للصلاحيات من خلال إدخال حالة تفويض مقصودة (Controlled Misconfiguration) وتحليلها باستخدام الأداة المطورة.

يعتمد السيناريو على إنشاء مستخدم بشري غير إداري (Non-admin User)، ومنحه صلاحيات على مستوى النظام (System Scope) عبر دور افتراضي واسع الصلاحيات (reader)، وذلك عبر الانتماء إلى مجموعة (Group Membership).

تم اختيار هذا السيناريو كونه يعكس نمطاً شائعاً من أخطاء الضبط في بيئات OpenStack، حيث يُفترض أن يقتصر نطاق أدوار مثل reader أو member على سياقات أضيق (Project / Domain)، وليس على المستوى النظامي الشامل.

يهدف هذا السيناريو إلى اختبار قدرة النظام على:

- اكتشاف الصلاحيات الواسعة الممنوحة لمستخدمين بشريين.
- تحليل مسارات الوصول غير المباشرة الناتجة عن سياسات التفويض.
- ربط النتائج بضوابط أمنية قياسية دون الاعتماد على أي بيانات تشغيلية.

4.3.1 تنفيذ السيناريو وجمع البيانات

بعد إنشاء المستخدم وتعيين الأدوار المطلوبة، تم تشغيل خط المعالجة الكامل للأداة، والذي يشمل:

- جمع بيانات IAM من Keystone.
 - تطبيق البيانات وتحويلها إلى نموذج موحد.
 - بناء الرسم البياني البنيوي لإدارة الهوية والصلاحيات.
 - تنفيذ تحليل الوصول (Reachability Analysis).
 - تطبيق القواعد الساكنة المعرفة مسبقًا.
- نتج عن هذه العملية إنشاء مجموعة من الملفات التحليلية (Snapshots) التي تمثل:
- التعيينات الفعلية للصلاحيات.
 - الرسم البياني للعلاقات.
 - مسارات الوصول من الأدوار إلى العمليات.
 - مخرجات القواعد الساكنة على شكل مؤشرات أمنية منظمة.

4.3.2 النتائج المكتشفة بواسطة القواعد الساكنة

أدى تطبيق القواعد الساكنة إلى توليد عدد من المؤشرات الأمنية (Security Indicators) التي تعكس أنماط ضبط قد تشكل خطورة محتملة في بيئة الإنتاج.

من أبرز النتائج المكتشفة:

- **صلاحيات قراءة واسعة على المستوى النظامي (T1 – Excessive Privilege)**
تم رصد أن مستخدمًا بشريًا يمتلك دور reader على مستوى النظام (System Scope)، ما يمنحه قدرة واسعة على الاطلاع على موارد وخدمات متعددة تتجاوز الحاجة الوظيفية المعتادة. يعكس هذا النمط خرقًا مباشرًا لمبدأ أقل صلاحية (Least Privilege)، حيث إن أدوار القراءة النظامية قد تؤدي إلى كشف معلومات بنوية حساسة حول البيئة السحابية.
- **ضعف دلالي في سياسات التفويض (T4 – Policy Semantic Weakness)**
أظهرت نتائج التحليل أن بعض العمليات المرتبطة بخدمة Keystone تعتمد في سياساتها على دلالات عامة مثل role:admin أو is_admin، دون تقييد صريح للنطاق.

وجود هذه الدلالات، عند دمجها مع أدوار ذات نطاق نظامي، قد يؤدي إلى توسيع غير مقصود لسطح الوصول، حتى وإن لم يكن المستخدم مصنفًا كـ admin بشكل مباشر.

• تعريض واجهات إدارية حساسة (T9 – Admin Surface Exposure)

تم اكتشاف إمكانية وصول مستخدم غير إداري إلى عمليات تؤثر على:

- الكتالوج.

- نقاط النهاية (Endpoints).

- الخدمات المعرفة على مستوى النظام.

هذا النمط لا يعني بالضرورة تنفيذ عملية ضارة، لكنه يشير إلى تعريض واجهة إدارية حساسة لمستخدم لا يُفترض أن يمتلك هذا المستوى من الرؤية أو التأثير. إلا أنه يشكل مؤشراً بنيوياً على اتساع غير مبرر لسطح الإدارة (Administrative Surface)، وهو ما يتعارض مع ممارسات العزل الوظيفي الموصى بها.

4.3.3 تفسير النتائج وحدودها (Result Interpretation & Limitations)

من المهم التأكيد على أن النتائج الناتجة عن هذه المرحلة لا تُصنّف كحوادث أمنية مؤكدة، وإنما كمؤشرات بنيوية تستدعي المراجعة.

تعتمد الأداة بشكل حصري على:

• حالة IAM الساكنة.

• نموذج التفويض الرسمي.

• سياسات الوصول المعرفة.

ولا تعتمد على:

• سجلات الدخول.

• تسلسل الأحداث الزمنية.

• سلوك المستخدم الفعلي.

4.3.4 النتائج الإيجابية الكاذبة (False Positives)

نظراً لاعتماد الأداة على التحليل الساكن فقط، فمن الممكن أن تنتج بعض النتائج الإيجابية الكاذبة (False Positives)، وذلك لأسباب منهجية معروفة في هذا النوع من التحليل، من أبرزها:

- غياب السياق التشغيلي: قد تكون بعض الصلاحيات الواسعة مبررة وظيفياً في سياق معين (مثل مهام المراقبة أو التدقيق)، إلا أن هذا السياق لا يمكن استنتاجه من نموذج IAM وحده.
 - تحليل بنيوي محافظ (Conservative Analysis): تم تصميم القواعد بأسلوب محافظ (Fail-safe)، بحيث تفضّل الإبلاغ عن نمط محتمل الخطورة على تجاهله، حتى لو لم يُستغل فعلياً.
 - عدم دمج البيانات السلوكية: عدم توفر بيانات سلوكية أو زمنية يمنع التمييز بين صلاحية غير مستخدمة وصلاحية مستغلة فعلياً.
- تم تصميم النظام المقترح ليكون قابلاً للتوسّع، حيث يمكن مستقبلاً تقليل معدلات النتائج الإيجابية الكاذبة من خلال:

- دمج التحليل الساكن مع:
 - تحليل سلوكي (Behavioral Analysis).
 - بيانات زمنية (Temporal Correlation).
 - ربط النتائج مع أنظمة SIEM عند توفرها.
 - استخدام تقنيات تعلم الآلة (Machine Learning) لتصنيف النتائج اعتماداً على:
 - أنماط الاستخدام الفعلي.
 - تاريخ التفاعل مع الصلاحيات.
 - تكرار وتزامن الأحداث.
- وبذلك، تُستخدم القواعد الساكنة كطبقة أولى دقيقة وقابلة للتفسير، يتم تعزيزها لاحقاً بطبقات تحليل أكثر تعقيداً.
- وبذلك تُظهر النتائج التجريبية أن النظام المقترح قادر على:
- كشف أنماط ضبط غير آمن للصلاحيات.
 - ربط هذه الأنماط بضوابط أمنية قياسية.
 - تقديم نتائج قابلة للتفسير دون الحاجة إلى بيانات تشغيلية.
- كما تؤكد النتائج أن التحليل الساكن يشكل أساساً قوياً للتحليل الاستباقي في بيئات IaaS، وبتكامل مستقبلي مع آليات تحليل سلوكي أكثر تقدماً.
- شكّل هذا الفصل الإطار التطبيقي للمشروع، حيث تم تنفيذ وتوثيق المراحل العملية للنظام المقترح بدءاً من إعداد بيئة OpenStack باستخدام MicroStack، مروراً بجمع بيانات إدارة الهوية والصلاحيات

وتطبيعتها، وبناء النموذج البنيوي القائم على الرسوم البيانية، وانتهاءً بتطبيق القواعد الساكنة وتحليل النتائج التجريبية الناتجة عنها.

تم التركيز في هذا الفصل على تحويل المفاهيم النظرية المتعلقة بتحليل التفويض ومخاطر الصلاحيات المفرطة إلى تطبيق عملي قابل للتكرار، يعتمد حصرياً على التحليل الساكن لبنية IAM دون الاعتماد على بيانات تشغيلية أو سلوكية.

أتاح هذا التطبيق العملي اختبار الفرضيات التي طُرحت في الفصول السابقة، وأثبت أن تحليل بنية التفويض وحدها كافٍ للكشف عن أنماط ضبط غير آمن للصلاحيات، حتى في غياب أي نشاط هجومي فعلي. كما بيّن هذا الفصل أن التحليل الساكن قد يؤدي أحياناً إلى الإشارة لنتائج تبدو خطيرة رغم عدم استغلالها فعلياً. تمت معالجة ذلك من خلال اعتماد قواعد حذرة تهدف إلى التنبيه المبكر بدل تجاهل المخاطر المحتملة، مع التأكيد على إمكانية تحسين دقة النتائج مستقبلاً عبر إضافة تحليل سلوكي أو آليات تصنيف أكثر تقدماً.

وبذلك، يمثل هذا الفصل حلقة الوصل بين الأساس النظري للنظام المقترح ومرحلة التقييم والتحليل الشامل.

الخاتمة

يُمثل هذا المشروع تطبيقاً عملياً لمنهجية تحليل أمني تستهدف دراسة بنية إدارة الهوية والصلاحيات في البيئات السحابية، مع التركيز على الكشف المبكر عن أنماط الضبط غير الآمن للصلاحيات ضمن سياق البنية التحتية كخدمة (IaaS). وقد تم تحقيق ذلك من خلال تطوير أداة Cloud IAM Analyzer تعتمد على التحليل الساكن لسياسات التفويض، بدءاً من جمع البيانات، مروراً بتطبيقاتها وبناء نموذج بنيوي قائم على الرسوم البيانية، وصولاً إلى تطبيق قواعد ساكنة قابلة للتفسير.

اعتمد المشروع على بيئة اختبار قائمة على MicroStack لمحاكاة بيئة OpenStack واقعية، مما أتاح تحليل نموذج التفويض كما هو مطبق فعلياً، دون الاعتماد على افتراضات نظرية أو بيانات تشغيلية. وأظهر التطبيق العملي أن تحليل بنية الصلاحيات وحدها كافٍ لاكتشاف حالات صلاحيات مفرطة، ومسارات وصول غير مباشرة، وأنماط تفويض قد تشكل مخاطر أمنية محتملة، حتى في غياب أي نشاط هجومي فعلي.

كما تضمن النظام إنشاء مصيدة أمنية (HoneyPot) ضمن بيئة معزولة، صُممت كعنصر تجريبي داعم للبنية العامة للنظام، بهدف توفير نقطة تفاعل خاضعة للمراقبة يمكن الاستفادة منها مستقبلاً في ربط التحليل البنيوي بالسلوك العملي. وقد تم في هذا المشروع التركيز على إعداد المصيدة من الناحية المعمارية دون إدخالها في مرحلة استغلال أو ترابط تشغيلي مع منظومات تحليل أخرى.

أظهرت نتائج التحليل أن الاعتماد على التحليل الساكن قد يؤدي في بعض الحالات إلى ظهور مؤشرات تحتاج إلى مراجعة بشرية، وهو ما يُعد سمة معروفة لهذا النوع من التحليل. إلا أن هذا القيد تم التعامل معه من خلال تصميم قواعد تحليل محافظة وقابلة للتفسير، تفضّل التنبيه المبكر على إغفال المخاطر المحتملة، مع الحفاظ على وضوح مصدر كل نتيجة ومسار الوصول المؤدي إليها.

وبذلك، يقدّم هذا المشروع إطاراً منهجياً واضحاً لتحليل إدارة الهوية والصلاحيات في بيئات IaaS، ويمهّد لتطويرات مستقبلية للنظام يمكن البناء عليها عبر توسيع نطاق القواعد، أو دمج طبقات تحليل إضافية عند توفر البيانات التشغيلية والبنية الداعمة، بما يعزّز دقة التحليل وشموليته دون المساس بقابليته للتفسير.

- [1] Mell, P., & Grance, T. (2011). *The NIST Definition of Cloud Computing* (NIST SP 800-145). National Institute of Standards and Technology.
- [2] Zhang, Q., Cheng, L., & Boutaba, R. (2010). *Cloud computing: State-of-the-art and research challenges*. *Journal of Internet Services and Applications*, 1(1), 7–18.
- [3] Sharma, S., Gupta, G., & Laxmi, P. R. (2014). *A survey on cloud security issues and techniques*. *arXiv*.
- [4] Gholami, A., & Laure, E. (2016). Security and privacy of sensitive data in cloud computing: A survey of recent developments. *arXiv*
- [5] Hashizume, K., Rosado, D. G., Fernández-Medina, E., & Fernandez, E. B. (2013). An analysis of security issues for cloud computing. *Journal of Internet Services and Applications*, 4(1), 5.
- [6] Chappell, D. (2010). *Introducing Windows Azure*. Microsoft Press.
- [7] Catteddu, D., & Hogben, G. (2009). *Cloud computing: benefits, risks and recommendations for information security*. European Network and Information Security Agency (ENISA).
- [8] Jain, P. (2025). Identity and access management in the cloud. *International Journal of Scientific Research in Computer Science, Engineering and Information Technology*, 11(2), 1528–1535.
- [9] Spitzner, L. (2003). *Honeypots: Tracking Hackers*. Addison-Wesley.
- [10] Mokube, I., & Adams, M. (2007). Honeypots: Concepts, Approaches, and Challenges. *Proceedings of the 45th Annual Southeast Regional Conference*, 321–326.
- [11] Zuech, R., Khoshgoftaar, T. M., & Wald, R. (2015). Intrusion detection and Big Heterogeneous Data: a Survey. *Journal of Big Data*, 2(1), 3
- [12] Cloud Security Alliance. (2025). Top threats to cloud computing: Deep dive 2025. Cloud Security Alliance.
- [13] Microsoft Corporation. (2024). State of multicloud security report 2024. Microsoft .
- [14] Esther, D., Jonathan, G., et al. (2025). Cloud identity and access management (IAM) automation. ResearchGate .
- [15] Fixing privilege escalations in cloud access control with MaxSAT and graph neural networks. *Proceedings of an international conference on cloud security and access control*.
- [16] Pitkar, A. (2025). Cloud security automation through symmetry: Threat detection and response. *Journal of Cloud Security Automation*.

- [17]Valiyev, A. (2025). Cyber threat detection with honeypots. International Journal of Cybersecurity and Threat Intelligence.
- [18]Morić, Z., Dakić, V., & Regvart, D. (2025). Advancing cybersecurity with honeypots and deception strategies. Informatics, 12(1), Article 14 .
- [19]SkyEye: When your vision reaches beyond IAM boundary scope in AWS cloud. Proceedings of an international conference on cloud security.
- [20]Aljuneidi, M. (2025). Dynamic honeypot deployment for enhanced cybersecurity. Journal of Advanced Cyber Defense Systems.
- [21]Center for Internet Security. (2024). CIS benchmarks: Enhancing security configurations in multi-cloud infrastructures.